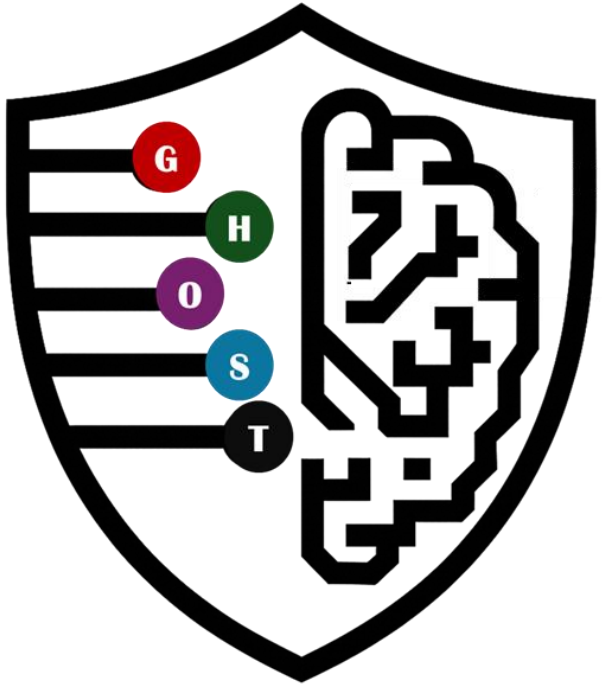
Project G.H.O.S.T by Team 29



A reimagined framework to model threats across online player behavior, system operations, and game-world ecosystems.

Table of Contents

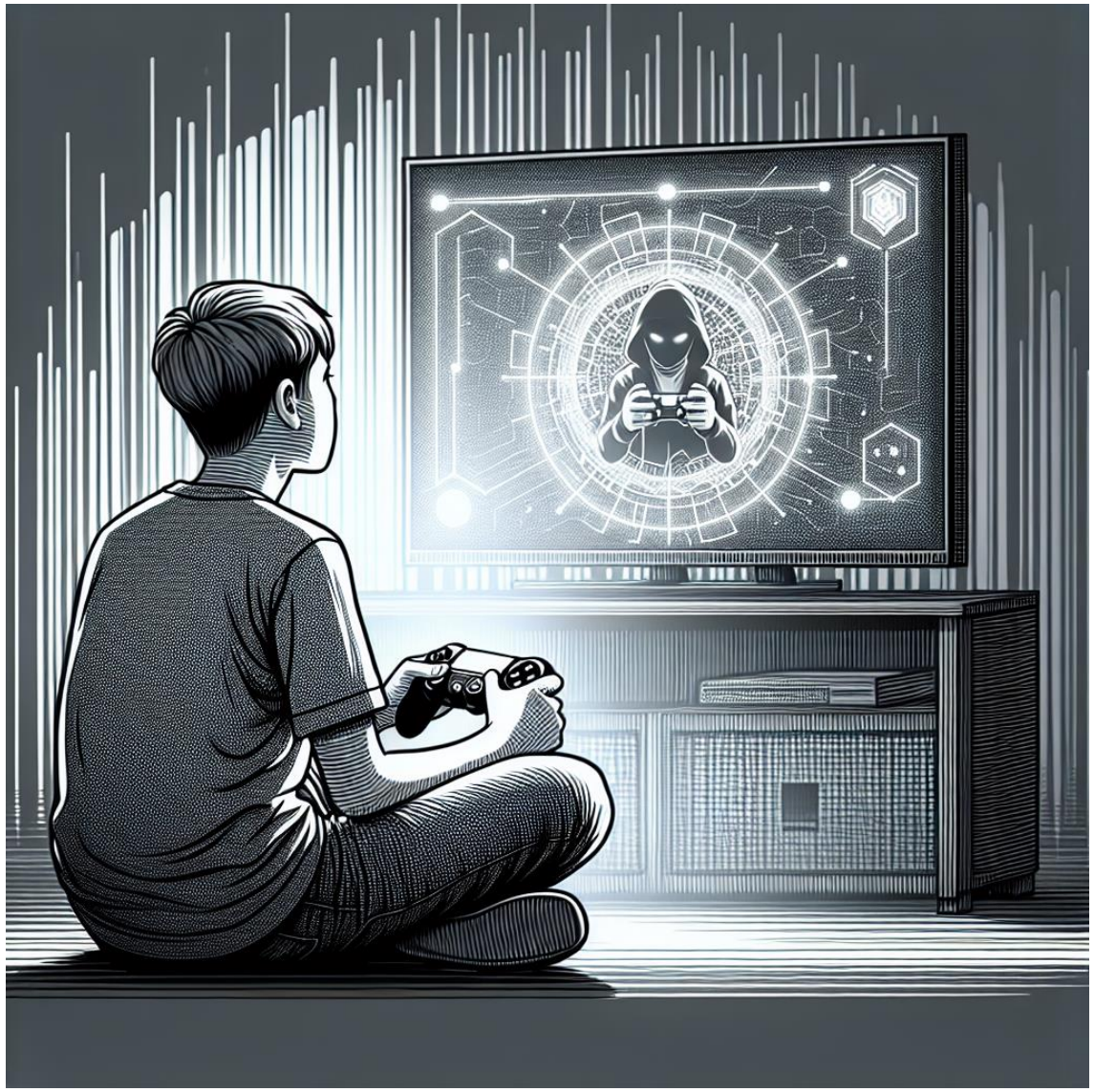
Our Aspiration	3
Current Business Architecture	6
Threat Modeling Scope	8
G.H.O.S.T Framework	12
System Decomposition Logic	15
Target Outcome	16
Threat Modeling for Chat Service (1)	18
Threat Modeling for Game Server (2)	24
Threat Modeling for Marketplace (3)	30
Threat Modeling for Media and Upload (4)	36
Analysis Reports and Graphs	42
Action Plan and Prioritization	44
Target Business Architecture	47
Future Outlook (Operationalizing G.H.O.S.T)	49
High Resolution Diagrams and References	51

Team 29
Our Aspiration for TMC 2026

What | Why | How

“protecting critical layers of the online player experience”

- Project G.H.O.S.T



WHAT | WHY | HOW

WHAT

Multiplayer games behave like live societies, not just software. Traditional threat models effectively cover core technical risks, but they don’t fully address player-to-player harm, economic manipulation, social dynamics, or emergent behaviors. To capture these, the **threat model needs to extend beyond its conventional boundaries.**

WHY

In this hackathon, we focus on modelling a subset of the ecosystem (Chat, Game Server, Marketplace, Upload/Media), using **a layered, player-centric approach** aligned with our top risks: safety, financial loss, and availability.

HOW

We introduce **G.H.O.S.T**., a new framework for Gameplay, Harm, Operations, Social, and Trade, enabling threat modelling across player behavior, social systems, the shared world, operational concerns, and the in-game economy.

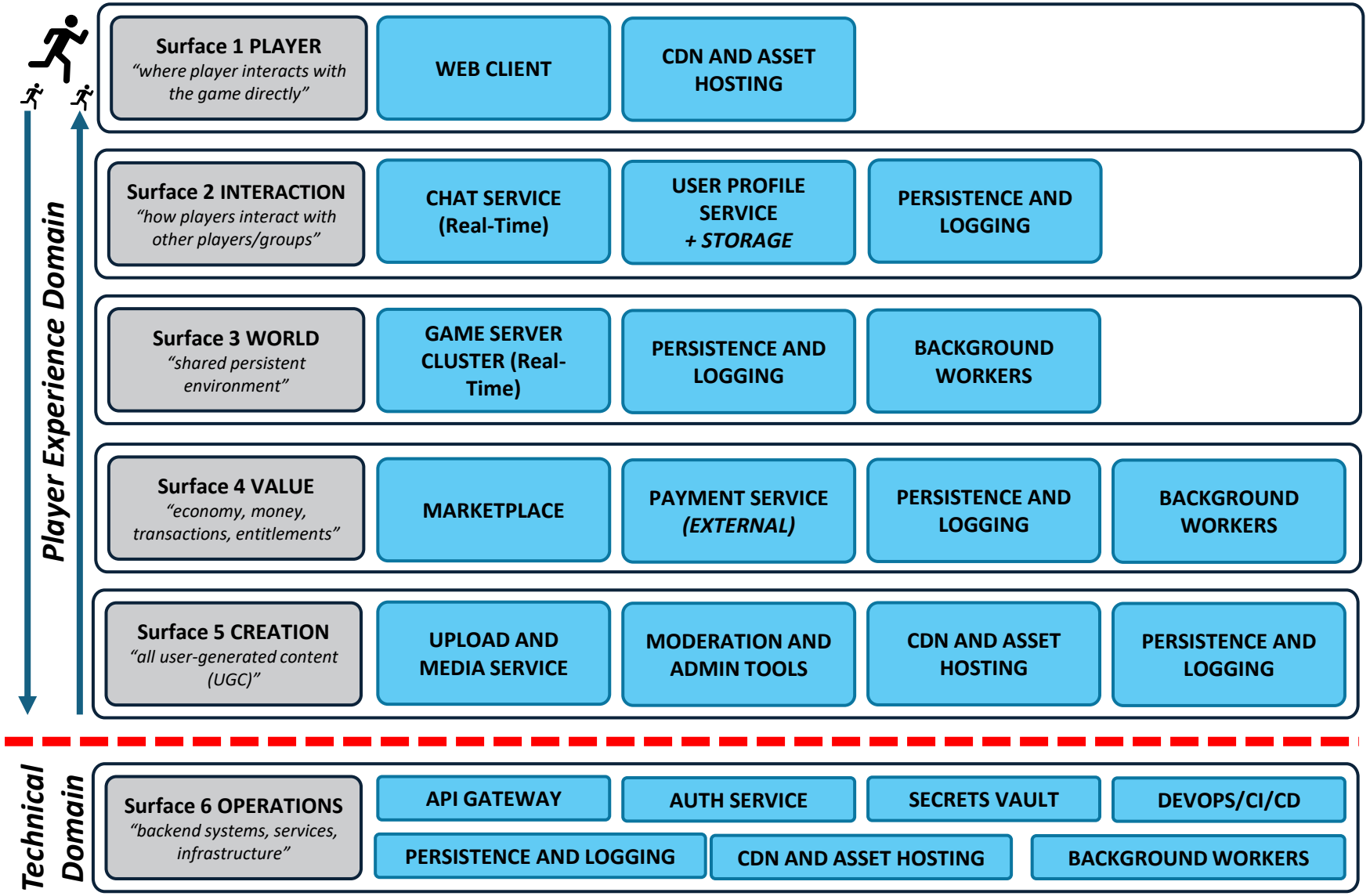
Current Business Architecture and Threat Modeling Scope

(*how we prioritize what to model ?*)

Business Architecture: Surface-Boundary Mapping for Game Ecosystems

Our Approach: We layer the architecture to ground threat modeling in the player's perspective, reveal where value and authority change hands, and align controls to the right domains. Surfaces 1-5 reflect the player experience; Surface 6 forms the technical domain.

Assumption: *Some components (e.g., Persistence & Logging) appear in both domains, but with distinct intent such as player-adjacent telemetry and audits (Surface 1-5) vs deep operational logging and retention (Surface 6) .*



Threat Modeling Scope: Assessment Criteria and Scoring Approach

***Scoping Approach** - By applying weighted 1 to 5 scores across key criteria, we determine which components present the highest risk to player safety, financial stability, and overall platform availability.*

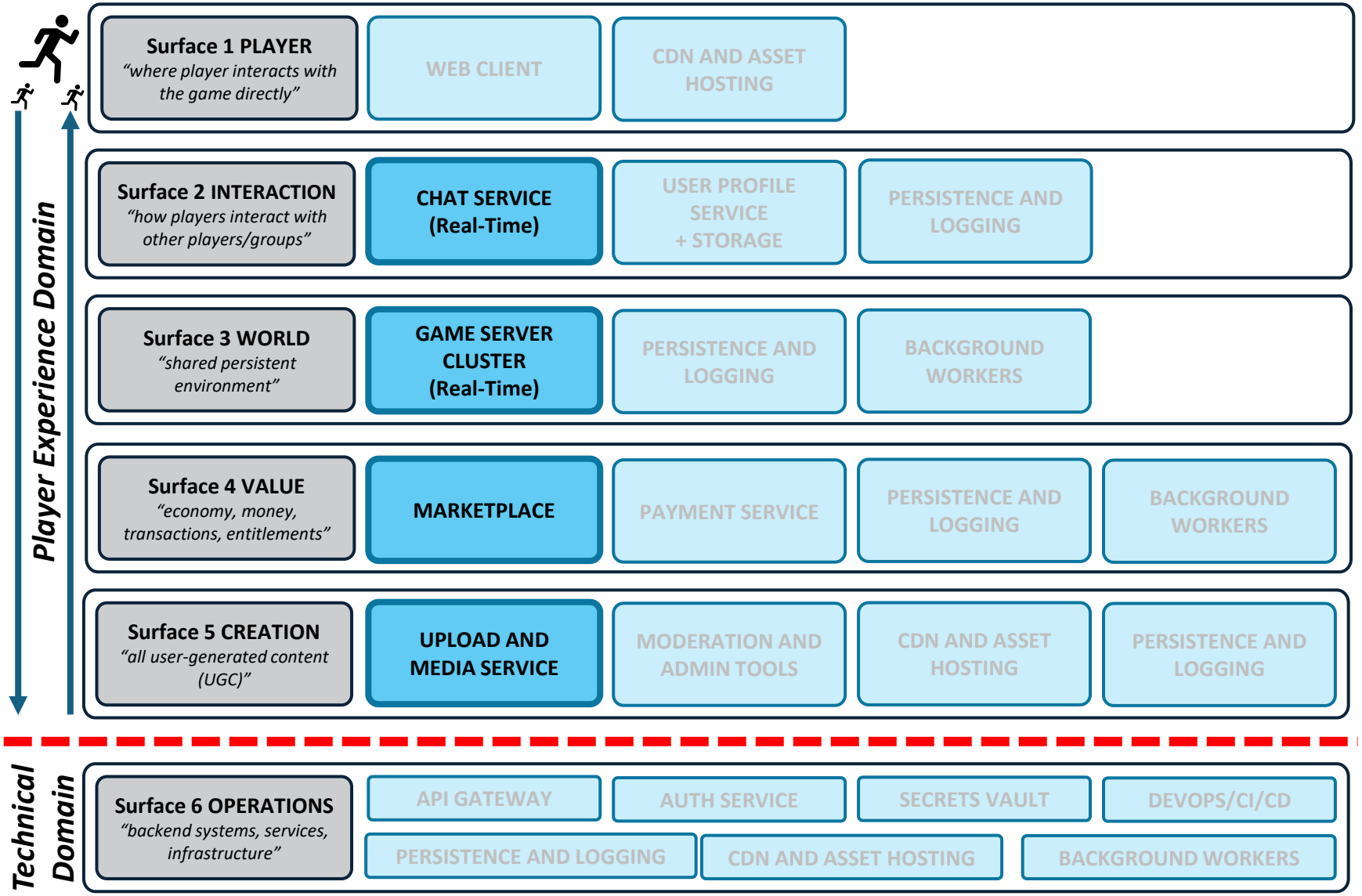
Assessment Criteria	Weight	Description | Scoring Scale = 1-Very Low, 2-Low, 3-Medium, 4-High, 5-Very High
Business Priority Alignment (PRI)	0.20	Ensures focus on components tied to top enterprise risks like safety, financial loss, and system availability.
Regulatory/Policy Exposure (RPE)	0.15	Highlights components subject to strict legal or policy requirements that increase compliance and liability risk.
User-Base Coverage (UBC)	0.15	Prioritizes components that affect the largest number of active users and therefore carry greater operational impact.
Age-Group Exposure (AGE-X)	0.15	Identifies components requiring enhanced protections due to significant usage by minors or younger audiences.
Propagation Potential (PP)	0.15	Measures how quickly failures or vulnerabilities in a component can spread to other systems.
Financial Exposure (FE)	0.10	Assesses the financial risk by evaluating components that handle or influence monetary transactions.
Impact on CIA (C, I, A)	0.10	Evaluates the severity of potential damage to confidentiality, integrity, or availability if the component is compromised.

*Risk Scoring Formula = (0.20*PRI)+ (0.15*RPE)+(0.15*UBC)+(0.15*AGE-X)+(0.15*PP)+(0.10*FE)+(0.10*CIA)*

Component List	PRI	RPE	UBC	AGE-X	PP	FE	CIA	Score
Chat Service (real-time)	5	4	5	5	5	3	4	**4.55**
Game Server Cluster (real-time backend)	5	4	5	3	5	4	5	**4.45**
Marketplace	5	5	4	3	4	5	5	**4.40**
Upload & Media Service	5	5	3	5	3	1	5	**4.00**
Auth Service (Identity)	4	3	5	3	5	3	4	**3.90**
Payment Service (External)	4	5	3	1	4	5	4	**3.65**
Persistence & Logging	3	3	5	1	4	2	4	**3.15**
API Gateway	2	2	5	1	4	1	4	**2.70**
Moderation & Admin Tools	4	4	1	2	4	2	4	**3.05**
Secrets Vault	3	3	1	1	5	2	5	**2.80**
Web Client (browser SPA)	2	2	5	3	3	1	3	**2.75**
User Profile Service + Storage	2	2	4	3	3	1	3	**2.60**
DevOps / CI/CD	3	3	1	1	4	2	4	**2.55**
Background Workers	2	2	3	1	3	3	3	**2.35**
CDN & Asset Hosting	2	2	5	1	3	1	2	**2.35**

Threat Modeling Scope: Highest-Impact Components and Selection Logic

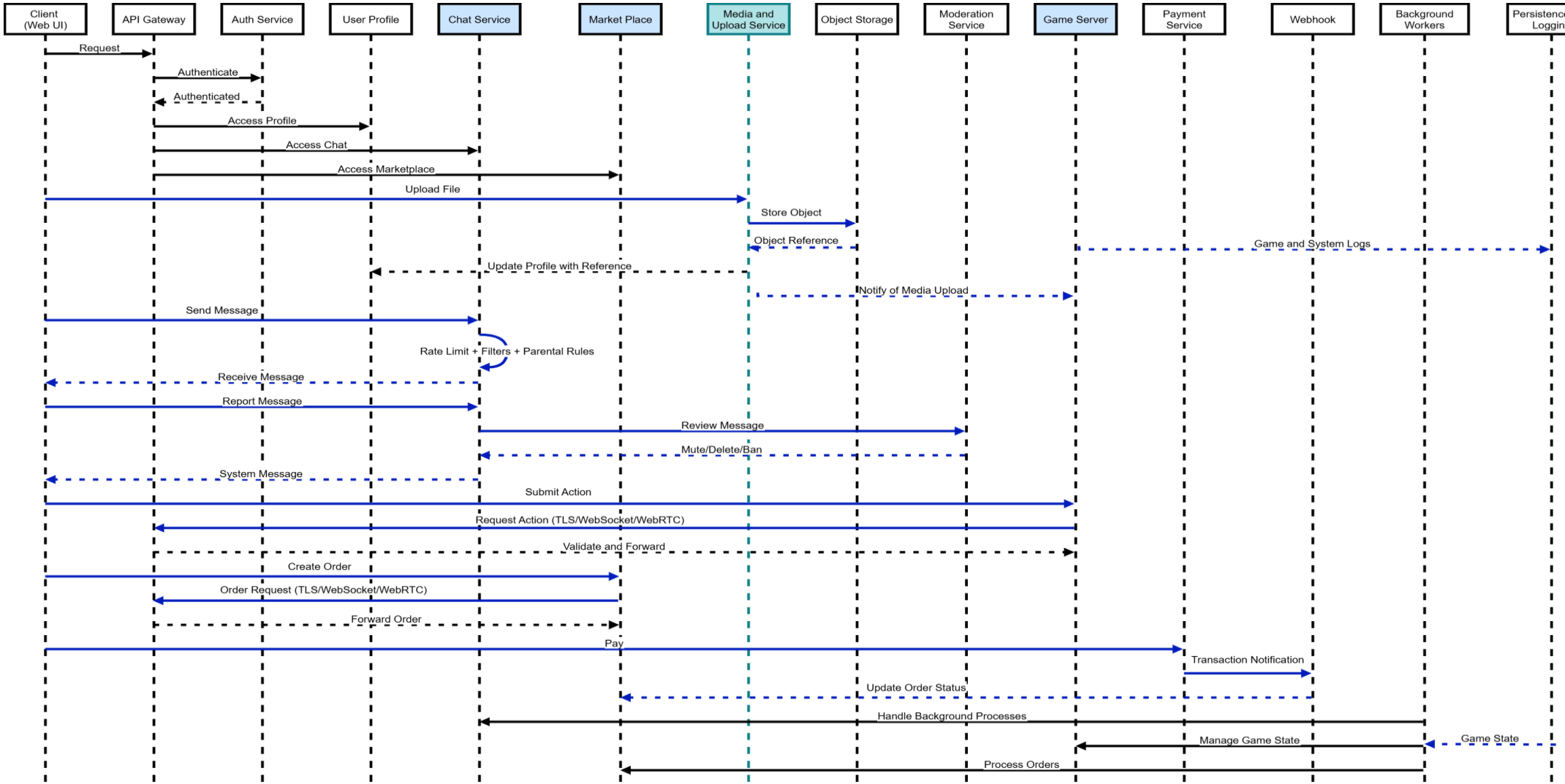
We selected **Chat, Game Server, Marketplace and Upload & Media** as our key focus areas because they score highest across our assessment criteria: Business Priority Alignment (PRI), regulatory relevance under GDPR/COPPA (RPE), user-base coverage (UBC), youth exposure (AGE-X), propagation potential (PP), financial exposure (FE) and CIA impact (confidentiality, integrity, availability). These four map directly to our top risks - player safety, financial loss, and platform availability..



Refer to the Appendix Slides for High Resolution Images of this DFD

DFD – High-Impact Components in Scope for Modeling

This sequential DFD highlights the high-impact components selected for threat modeling (Chat, Game Server, Marketplace, Media and Upload) and form the foundation for the focused G.H.O.S.T. analysis that follows.



In Scope Services

Our Threat Modeling Framework

G.H.O.S.T

Rethinking Threat Modeling for Modern Multiplayer Games Introducing G.H.O.S.T (**G**ameplay, **H**arm, **O**perations, **S**ocial, **T**rade)

Strategic multiplayer games function as socio-technical ecosystems rather than mere software systems, so traditional, software-centric threat models (e.g., STRIDE/DREAD) are limited in capturing gameplay dynamics and player-to-player threat surfaces. **The G.H.O.S.T framework fills this gap** by examining the game world, its players, the interactions and emergent behaviors that shape multiplayer ecosystems.

Refer to the footer link for an independent analysis of conventional threat-modeling frameworks.

G **"Gameplay"** - *Threats that exploit or break the core rules and fairness of the game.*

H **"Harm"** - *Threats that expose players to abuse, manipulation, or unsafe content.*

O **"Operations"** - *Threats that disrupt the game's stability, availability, or backend systems.*

S **"Social"** - *Threats that misuse relationships, chat, alliances, or community interactions.*

T **"Trade"** - *Threats that distort the in-game economy through fraud or value manipulation.*

Reference: Evaluating Threat Modeling Methodologies | CMS Information Security and Privacy Program

Expanding G.H.O.S.T – Representative and Critical Threat Categories

*This overview highlights **three high-impact threat concepts** under each G.H.O.S.T category, selected for their relevance to safety, financial exposure, and availability. Component specific threat testing will be tailored according to the service chosen for deeper evaluation.*

G1 EXPLOITS "breaking mechanics"	**H1** HARASSMENT "targeted abuse"	**O1** DDoS "overwhelming servers"	**S1** CLAN INFILTRATON "joining to sabotage"	**T1** ITEM DUPING "duplicating value"
G2 CHEATS "automated inputs"	**H2** GROOMING "manipulating minors"	**O2** PACKET TAMPERING "malformed data"	**S2** NAME IMPERSONATION "look-alike identity"	**T2** MARKET FRAUD "scam listings"
G3 DESYNC "state divergence"	**H3** TOXICITY "offensive language"	**O3** API OVERLOAD "spam requests"	**S3** GROUP BRIGADING "coordinated attacks"	**T3** PRICE FIXING "collusive control"

System Decomposition for Threat Analysis

Services | Data Store | Data Flows

Component Decomposition: Services | Data Store | Data Flow

*We decompose each component into **Services, Datastores, and Dataflows** to expose trust boundaries, pinpoint authority and value transitions, and make threats, controls, and tests directly mappable. Below are the reasons to organize our components this way!*

Player-Centric Clarity

- Separates what the system does (Services), what it holds (Datastores), and how it moves value and authority (Dataflows). This mirrors the way players experience features and how risks materialize.

Clear Trust Boundaries

- Dataflows are where identity, value, and authority change hands; Datastores define crown jewels; Services define control points.

Direct Mapping to Threats and Controls

- Services - logic, safety checks, ops safeguards
- Data Stores - confidentiality & integrity
- Data Flows - availability risks, social vectors, trade/economy transactions

Ownership & testability

- Makes it easy to assign owners, define SLIs/SLOs, and create targeted test cases per boundary.

Ownership & testability

- A common pattern for Chat, Game Server, Marketplace - so teams can model quickly and consistently.

Threat Modeling Outcome Using G.H.O.S.T Framework

(What we will deliver !)

Threat Dashboard and Threat Radar

Threat Dashboard and Threat Radar (Early View on Target Deliverable)

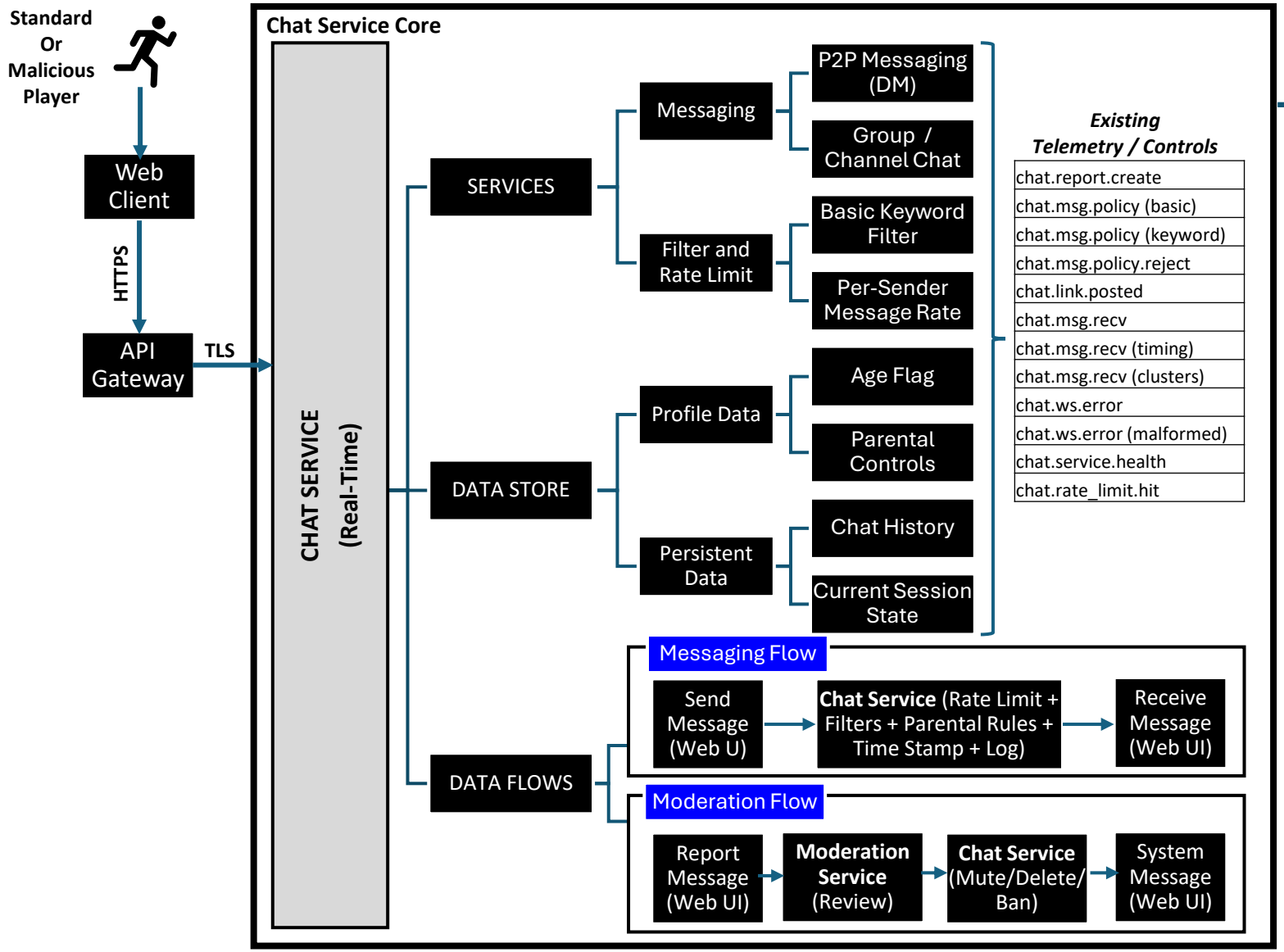
This dashboard and radar is an actual representation of the threat modeling completed for the chat, game server, marketplace and media & upload services using the G.H.O.S.T framework. It highlights how high-impact, representative threats map to each system component.

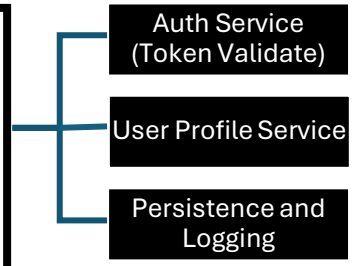
The upcoming slides will detail the threat modeling process in detail for each component and will show how we achieved the below results.

#	System Component	G1	G2	G3	H1	H2	H3	O1	O2	O3	S1	S2	S3	T1	T2	T3	Risk Level
1	Chat Service (real-time)	🟢	🟢	🟢	🔴	🔴	🔴	🟢	🟢	🔴	🟢	🔴	🔴	🟢	🔴	🟢	🟥
2	Game Server Cluster (real-time)	🔴	🔴	🔴	🟢	🟢	🟢	🔴	🔴	🔴	🟢	🔴	🔴	🔴	🟢	🟢	🟥
3	Market Place	🔴	🔴	🟢	🟢	🟢	🟢	🔴	🔴	🔴	🟢	🟢	🔴	🔴	🔴	🔴	🟥
4	Media and Upload Service	🔴	🔴	🟢	🟢	🟢	🟢	🔴	🔴	🔴	🟢	🟢	🔴	🟢	🟢	🟢	🟨

Team 29
Threat Modeling in Action
(Service # 1 - Chat Service)

Chat Service: Existing-State Architecture, Dependencies & Assumptions





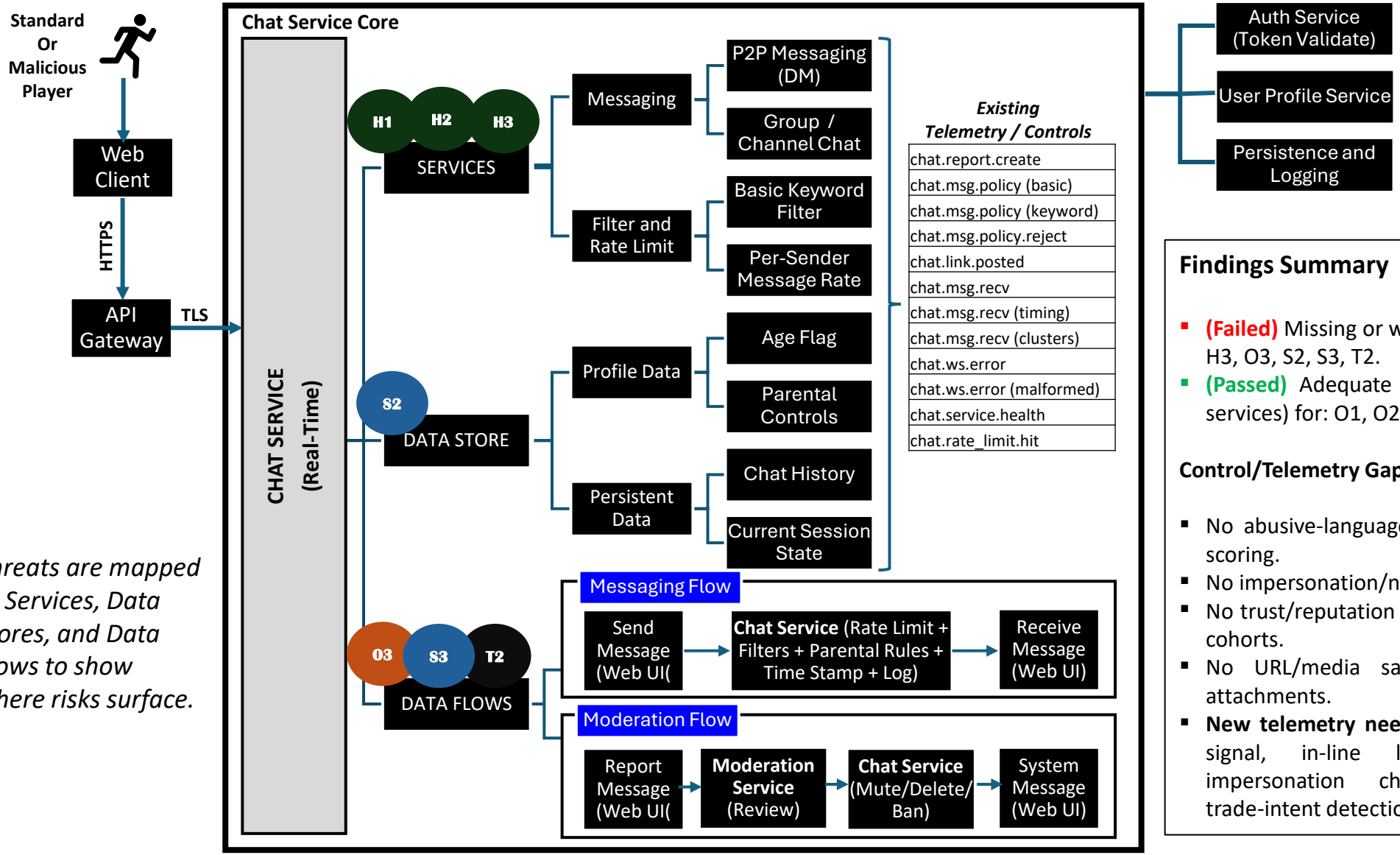
Assumptions

- Actor is a player "Standard or Malicious" using an unmodified Web UI/client.
- All upstream systems (Auth, User Profile, Web UI, API Gateway, Persistence/Logging) already exist and are reliable.
- Auth service manages tokens; Chat only performs lightweight validation.
- User Profile supplies presence, privacy, and block/mute info needed for chat decisions.
- API Gateway handles TLS, WebSocket upgrades, and routing to Chat.
- Persistence/Logging stores all messages and moderation records durably and immutably.
- Existing telemetry signals (e.g., policy checks, message receipt, link detection, errors, rate limits, reports, and health signals) are assumed to be reliably emitted and consumed, and are used both for service observability and as control points to enforce policy, detect abuse, and guide automated or manual moderation actions.

Chat Service - G.H.O.S.T. Threat Coverage and Control Gaps Analysis

Threat ID	Threat Name	Test Case	Existing Telemetry (Current Controls)	Finding	Result	Remediation Actions (Add Missing Telemetry & Controls)
G1	EXPLOTS	Post exploit how-to and macro steps in chat; observe spread only.	chat.msg.policy (keyword),	Not Possible to "Trigger Explots" ony via Chat. Governance is External – Gameserver Telemetry	**PASS**	
G2	CHEATS	DM a known cheat-loader URL to 20 users within 5 minutes.	chat.link.posted chat.msg.policy.reject	Known Cheat-Loader URLs are Blocked with Existing Message Telemetry	**PASS**	
G3	DESYNC	Coordinate lag timing via chat	chat.msg.recv (timing)	Not Possible to "Trigger Desync" ony via Chat. Governance is External – Gameserver Telemetry	**PASS**	
H1	HARASSMENT	Send targeted abusive messages to a test user across multiple channels over 2 minutes.	chat.report.create chat.msg.policy (basic)	Existing message policies do cover 100% COPPA rules. Report creation is Reactive.	FAIL	**Implement -** chat.msg.score, chat.msg.policy.coppa
H2	GROOMING	Adult test account messages a minor-flagged test account with boundary-pushing prompts over 48h.	chat.msg.policy (basic)	Existing message policies do cover 100% COPPA rules. Report creation is Reactive.	FAIL	**Implement -** chat.msg.score, chat.msg.policy.coppa
H3	TOXICITY	Post sequences of offensive phrases in a public channel at normal cadence.	chat.msg.policy (basic)	Existing message policies do cover 100% COPPA rules. Report creation is Reactive.	FAIL	**Implement -** chat.msg.score, chat.msg.policy.coppa
O1	DDoS	Synthetic clients open/close WS at high RPS from diverse IPs (no auth spam).	chat.ws.error chat.service.health	Existing Throttling and Health Checks are found to be adequate to prevent DDoS attacks via Chat.	**PASS**	
O2	PACKET TAMPERING	Fuzz chat frames with malformed payloads.	chat.ws.error (malformed)	Existing Health Checks are found to be adequate to prevent Packet Tampering attacks via Chat.	**PASS**	
O3	API OVERLOAD	Authenticated account sends 100 msgs/s for 60s to one channel.	chat.rate_limit.hit,	Existing Rate Limit Configuration do not consider the time and multi-user dimension	**FAIL**	**Implement -** chat.inline.latency
S1	CLAN INFILTRATION	Join a test clan and attempt manipulation via chat	chat.msg.recv	A "Clan Infiltration" is a Qualitative Threat and was not identified only via the Chat Channel.	**PASS**	
S2	NAME IMPERSONATION	Create a homoglyph display name colliding with a high-rep user; post in region chat.		No controls and telemetry found for Name Impersonation based on Homoglyphs.	**FAIL**	**Implement -** chat.impersonation.check
S3	GROUP BRIGADING	30 test accounts raid a channel (10 msgs each in 60s).	chat.rate_limit.hit;	Existing Rate Limit Configuration do not consider the time and multi-user dimension	**FAIL**	**Implement -**chat.inline.latency chat.rate_limit.cohort,
T1	ITEM DUPING	Share "dupe" instructions via DMs.	chat.msg.policy (keyword)	Not Possible to "Dupe Item" ony via Chat Service. Governance is External – Economy Monitors	**PASS**	
T2	MARKET FRAUD	DM off-platform escrow invites + phishing link to 10 users.	chat.link.posted;	Existing Link Validation Capabilities work out of a Known List e.g., Cheat Loader URLs Only.	**FAIL**	**Implement -** chat.url.verdict, chat.trade.intent
T3	PRICE FIXING	Coordinate fixed prices in private chat; watch synchronized listings.	chat.msg.recv (clusters)	Not Possible to "Price Fix" ony via Chat Service. Governance is External – Marketplace Analytics	**PASS**	

Chat Service - G.H.O.S.T Threat Landscape and Findings



Threats are mapped to Services, Data Stores, and Data Flows to show where risks surface.

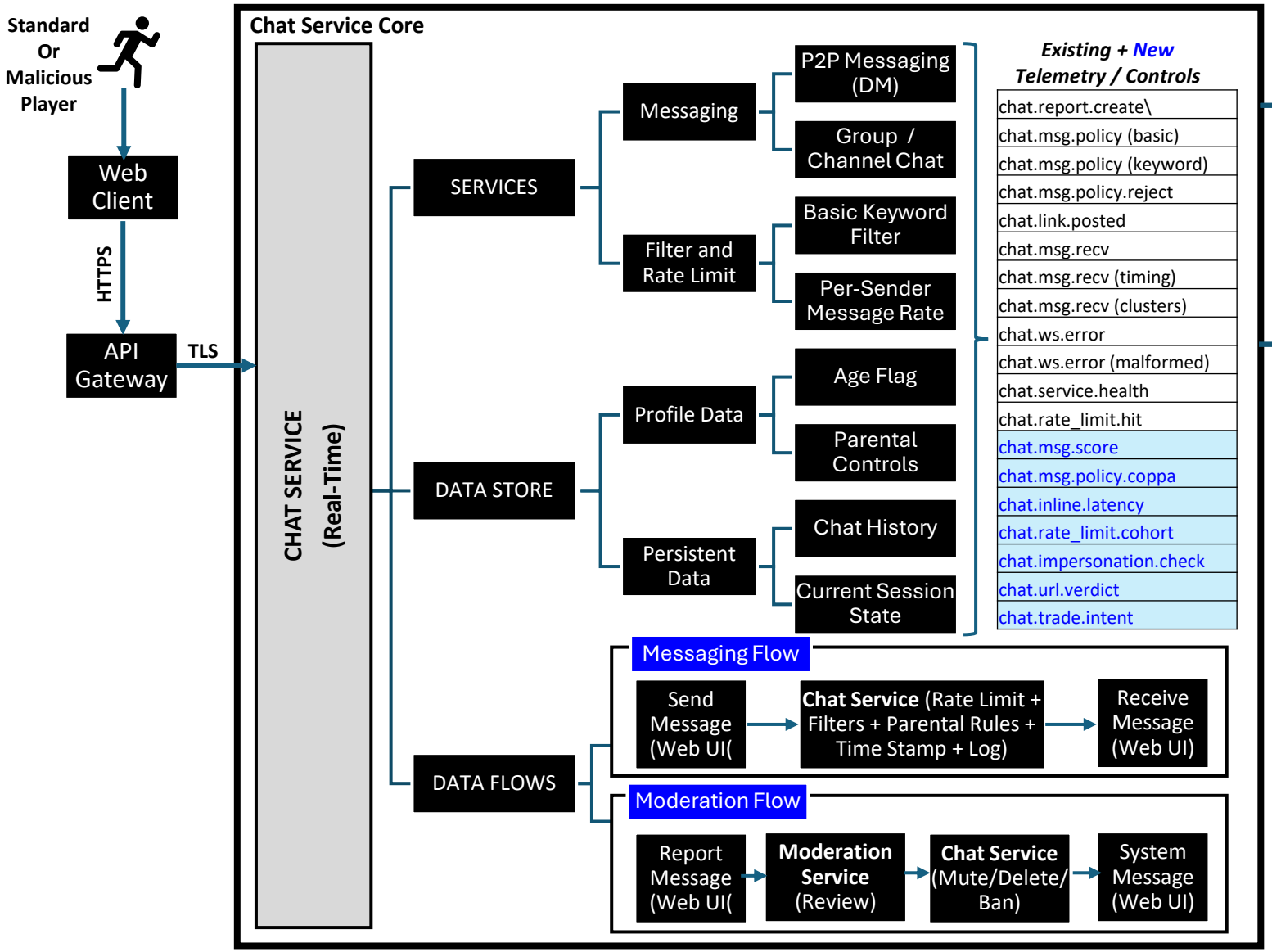
Findings Summary

- **(Failed)** Missing or weak controls for threats H1, H2, H3, O3, S2, S3, T2.
- **(Passed)** Adequate controls (or handled in other services) for: O1, O2, S1,G2, G1, G3, T1, T3

Control/Telemetry Gaps Identified

- No abusive-language detection or in-line message scoring.
- No impersonation/name-similarity checks.
- No trust/reputation model to throttle risky users or cohorts.
- No URL/media safety verdicting for links or attachments.
- **New telemetry needed** - message scoring, COPPA signal, in-line latency, cohort rate-limits, impersonation checks, URL verdicts, and trade-intent detection.

Chat Service: Target-State Architecture, Controls and Remediation Strategy



New AI-Driven Safety Controls

- **Abusive Language Detector AI** – identifies toxic, harmful, or abusive message content.
- **Impersonation Detector AI** – flags suspicious name-similarity or identity-spoofing attempts.
- **Reputation Trust-Graph** – models user trust levels and behavior history to guide throttles and controls.

Additional Telemetry to be Implemented

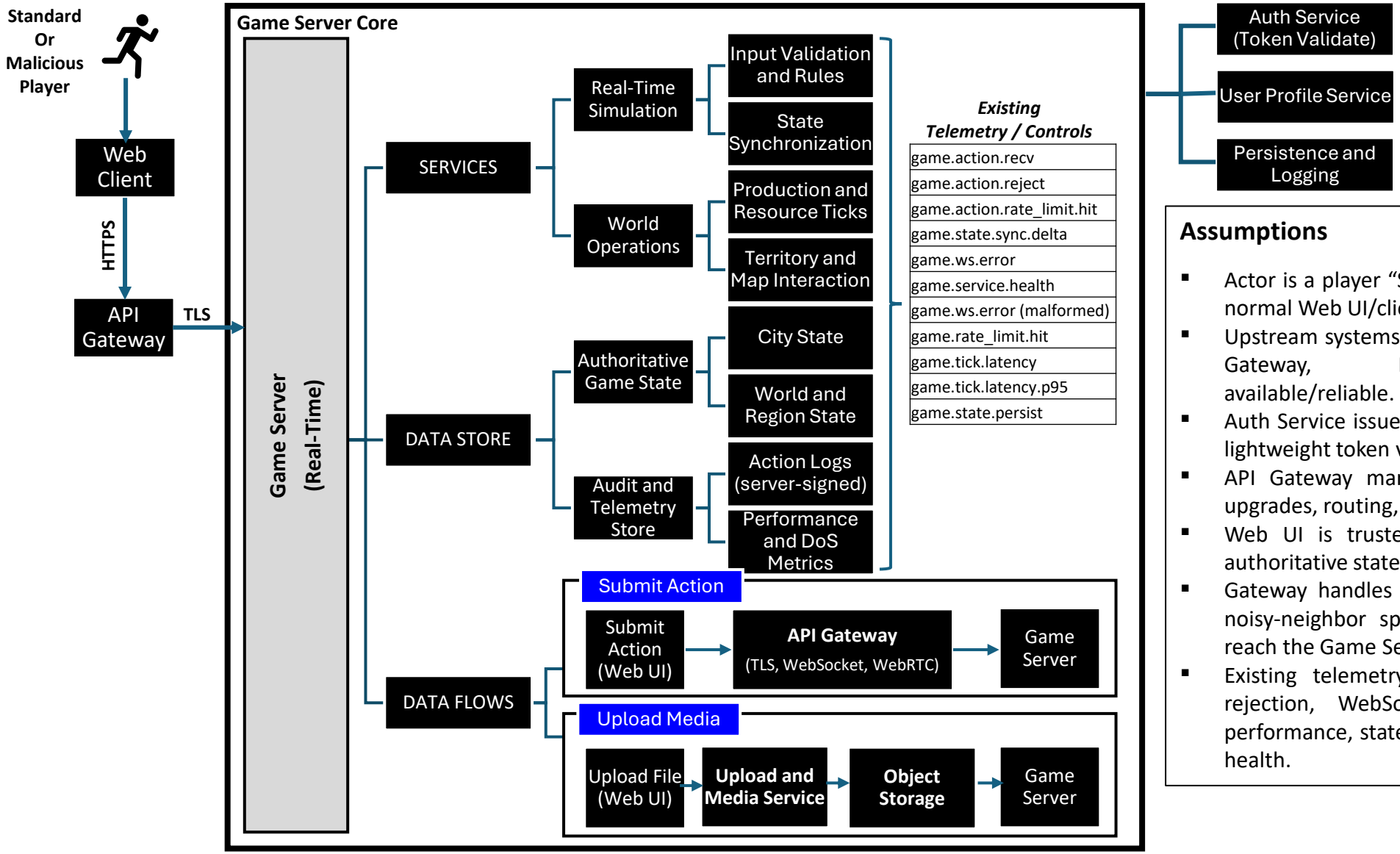
- chat.msg.score - in-line toxicity/abuse scoring.
- chat.msg.policy.coppa - youth-safety and underage protection signal.
- chat.inline.latency - measure overhead added by in-line scanners.
- chat.rate_limit.cohort - rate limiting based on trust/reputation tiers.
- chat.impersonation.check - detection of display-name similarity.
- chat.url.verdict - link reputation/safety classification.
- chat.trade.intent - detection of high-risk solicitation patterns.

Chat Service – Catalog of Telemetry and Control Signals

Telemetry / Control	Description
chat.report.create	User-generated abuse/report submissions
chat.msg.policy (basic)	Basic policy checks applied to messages
chat.msg.policy (keyword)	Keyword-based policy inspection
chat.msg.policy.reject	Message rejected due to policy violation
chat.link.posted	Link detection within messages
chat.msg.recv	Message reception event
chat.msg.recv (timing)	Latency/timing for message receipt
chat.msg.recv (clusters)	Cluster-level routing/processing trace
chat.ws.error	Generic WebSocket errors
chat.ws.error (malformed)	Malformed frames or invalid payloads
chat.service.health	Overall Chat service health indicators
chat.rate_limit.hit	Rate-limit enforcement events
chat.msg.score	In-line toxicity/abuse scoring
chat.msg.policy.coppa	Youth-safety / underage protection signal
chat.inline.latency	Measures overhead from in-line scanning
chat.rate_limit.cohort	Rate limiting based on trust/reputation tiers
chat.impersonation.check	Detection of display-name similarity or impersonation
chat.url.verdict	URL reputation and safety classification
chat.trade.intent	Detection of high-risk trade/solicitation intent

Team 29
Threat Modeling in Action
(Service # 2 - Game Server)

Game Server: Existing-State Architecture, Dependencies & Assumptions



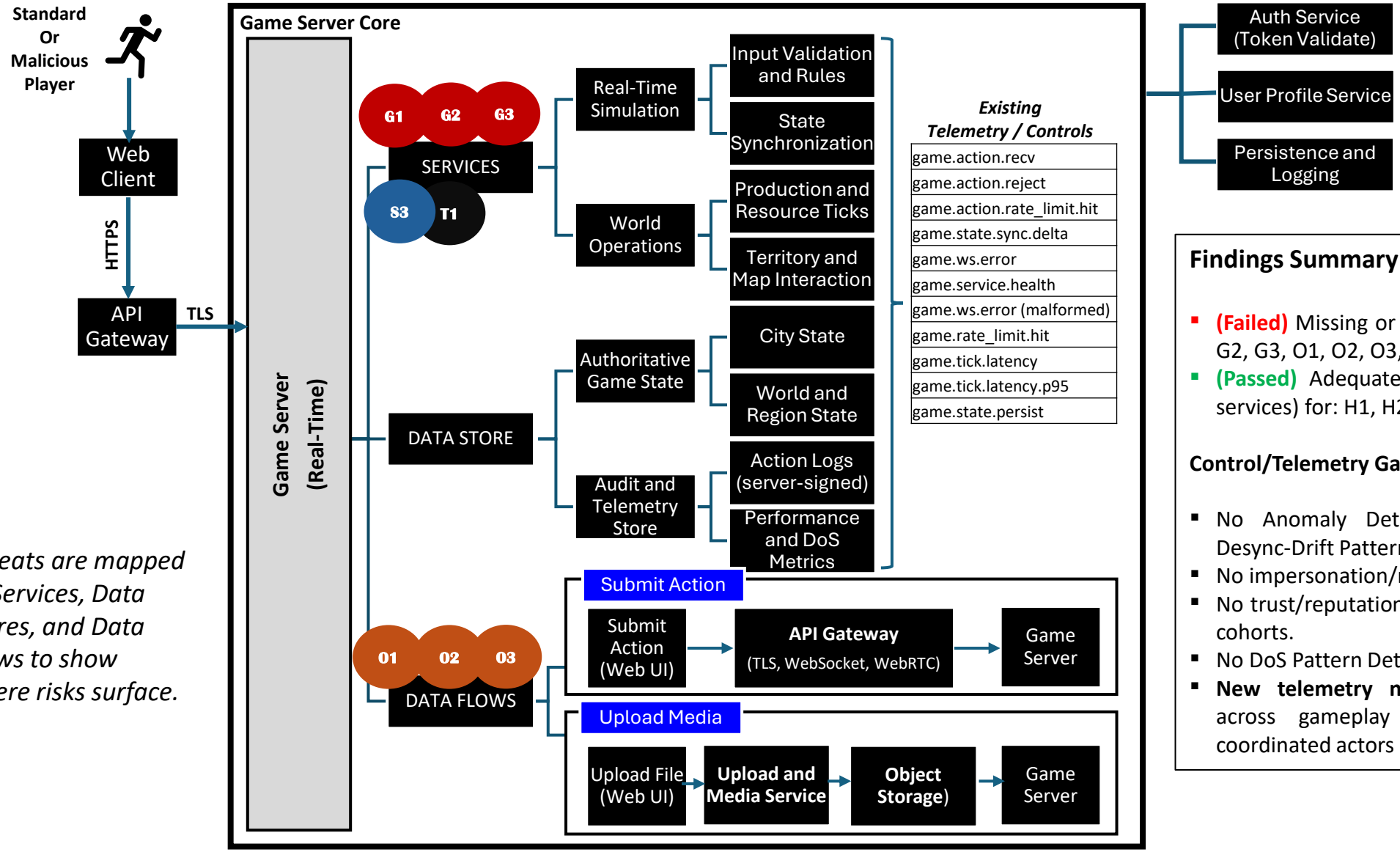
Assumptions

- Actor is a player "Standard or Malicious" using the normal Web UI/client.
- Upstream systems (Auth, User Profile, Web UI, API Gateway, Persistence/Logging) are available/reliable.
- Auth Service issues tokens; Game Server performs lightweight token validation only.
- API Gateway manages TLS, WebSocket/WebRTC upgrades, routing, and basic rate-limits.
- Web UI is trusted only for rendering, not for authoritative state or validation.
- Gateway handles initial limits, but action floods, noisy-neighbor spam, and burst inputs can still reach the Game Server.
- Existing telemetry covers action intake, action rejection, WebSocket errors, rate-limits, tick performance, state persistence, and overall service health.

Game Server - G.H.O.S.T. Threat Coverage and Control Gaps Analysis

Threat ID	Threat Name	Test Case	Existing Telemetry (Current Controls)	Finding	Result	Remediation Actions (Add Missing Telemetry & Controls)
G1	EXPLOTS	Attempt impossible actions (e.g., build without resources); verify server rejects and logs.	game.action.recv game.action.reject	Existing game action policies do cover 100% rule violations.	**FAIL**	game.exploit.flag (rule-violation classifier)
G2	CHEATS	Use a macro to send perfectly timed repetitive actions; confirm rate-limits and anomaly detection.	game.action.rate_limit.hit	Existing game action policies do cover unexpected patterns like bot detection.	**FAIL**	game.action.pattern.anomaly (bot/timing detection)
G3	DESYNC	Induce client lag (proxy delay), act during desync; verify server authoritative correction.	game.state.sync.delta game.ws.error	Existing state checks do cover externally induced desync patterns	**FAIL**	game.desync.detected (state drift detector)
H1	HARASSMENT	Send targeted abusive messages to a test user across multiple channels over 2 minutes.	(Not Applicable)	Not Possible in "Game Server Boundary" Governance is External – Chat Telemetry	**PASS**	
H2	GROOMING	Adult test account messages a minor-flagged test account with boundary-pushing prompts over 48h.	(Not Applicable)	Not Possible in "Game Server Boundary" Governance is External – Chat Telemetry	**PASS**	
H3	TOXICITY	Post sequences of offensive phrases in a public channel at normal cadence.	(Not Applicable)	Not Possible in "Game Server Boundary" Governance is External – Chat Telemetry	**PASS**	
O1	DDoS	High-rate WS connects/opens/closes to overload Game Server.	game.ws.error game.service.health	Existing Throttling and Health Checks are not adequate detect all DoS patterns.	**FAIL**	game.dos.signature (burst window detector)
O2	PACKET TAMPERING	Send malformed/oversized WS frames or corrupted action payloads.	game.ws.error (malformed) game.action.reject	Existing Health Checks are not adequate prevent Packet Tampering attacks via Chat.	**FAIL**	game.packet.reject.reason (schema-specific)
O3	API OVERLOAD	Spam 200+ actions/sec to saturate tick loop/queues; observe throttling and latency.	game.rate_limit.hit game.tick.latency.p95	Existing Rate Limit Configuration do not consider the time and multi-user dimension	**FAIL**	game.overload.threshold.exceeded
S1	CLAN INFILTRATION	Governance/social manipulation; Join a test clan and attempt manipulation,	(Not Applicable)	Not Possible in "Game Server Boundary" Governance is External – Chat Telemetry	**PASS**	
S2	NAME IMPERSONATION	Create a homoglyph display name colliding with a high-rep user; Use in Game.		No controls and telemetry found for Name Impersonation based on Homoglyphs.	**FAIL**	game.impersonation.check
S3	GROUP BRIGADING	20–30 accounts spam movement/build actions simultaneously to overload tick loop.	game.rate_limit.hit game.tick.latency	Existing Rate Limit Configuration do not consider the time and multi-user dimension	**FAIL**	game.cohort.activity (correlated offender grouping)
T1	ITEM DUPING	Race condition during transfers/upgrades/state updates; verify atomicity and rollback.	game.action.reject game.state.persist	Existing state checks do cover externally induced desync patterns	**FAIL**	game.duplication.detected (atomicity/rollback mismatch)
T2	MARKET FRAUD	Marketplace/Chat-driven fraud; Game Server holds world state only.		Not Possible in "Game Server Boundary" Governance is External – Marketplace Telemetry	**PASS**	
T3	PRICE FIXING	Marketplace-level coordination; Game Server has no pricing logic.		Not Possible in "Game Server Boundary" Governance is External – Marketplace Telemetry	**PASS**	

Game Server - G.H.O.S.T Threat Landscape and Findings



Threats are mapped to Services, Data Stores, and Data Flows to show where risks surface.

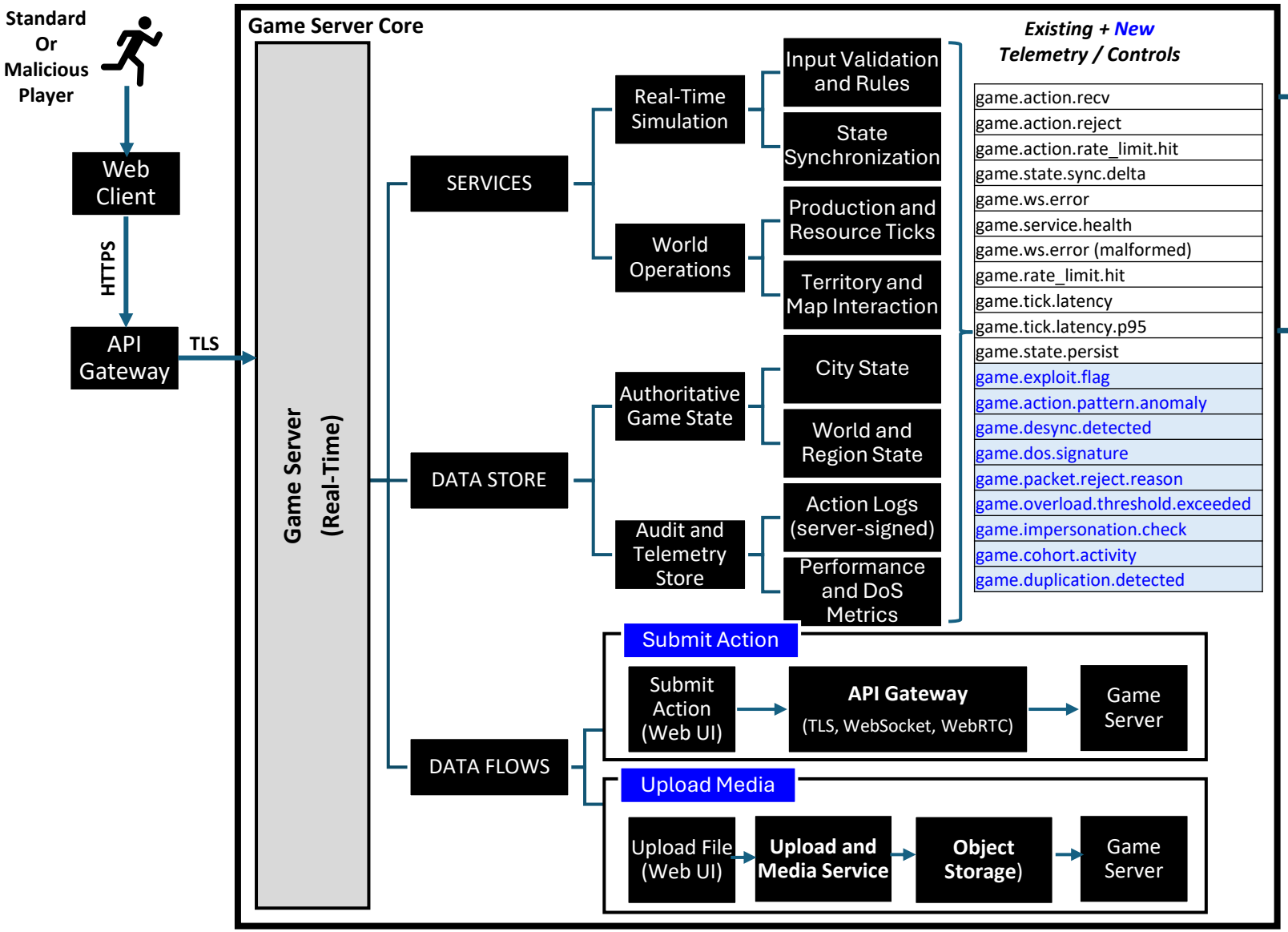
Findings Summary

- **(Failed)** Missing or weak controls observed for: G1, G2, G3, O1, O2, O3, S3, T1.
- **(Passed)** Adequate controls (or handled in other services) for: H1, H2, H3, S1, S2, T2, T3.

Control/Telemetry Gaps Identified

- No Anomaly Detection for Rule-Violation and Desync-Drift Patterns.
- No impersonation/name-similarity checks.
- No trust/reputation model to throttle risky users or cohorts.
- No DoS Pattern Detectors.
- **New telemetry needed** for anomaly detection across gameplay integrity, drift, DoS bursts, coordinated actors and impersonation.

Game Server: Target-State Architecture, Controls and Remediation Strategy



Auth Service (Token Validate)

User Profile Service

Persistence and Logging

Anomaly Detector AI

DoS Pattern Detector

Impersonation Detector AI

Reputation Trust-Graph

New AI-Driven Safety Controls

- **Anomaly Detector AI** – identifies rule-violation, desync-drift patterns
- **DoS Pattern Detector** – detects burst windows and DoS signatures,
- **Impersonation Detector AI** – flags suspicious name-similarity or identity-spoofing attempts.
- **Reputation Trust-Graph** – models user trust levels and behavior history to guide throttles and controls.

Additional Telemetry to be Implemented

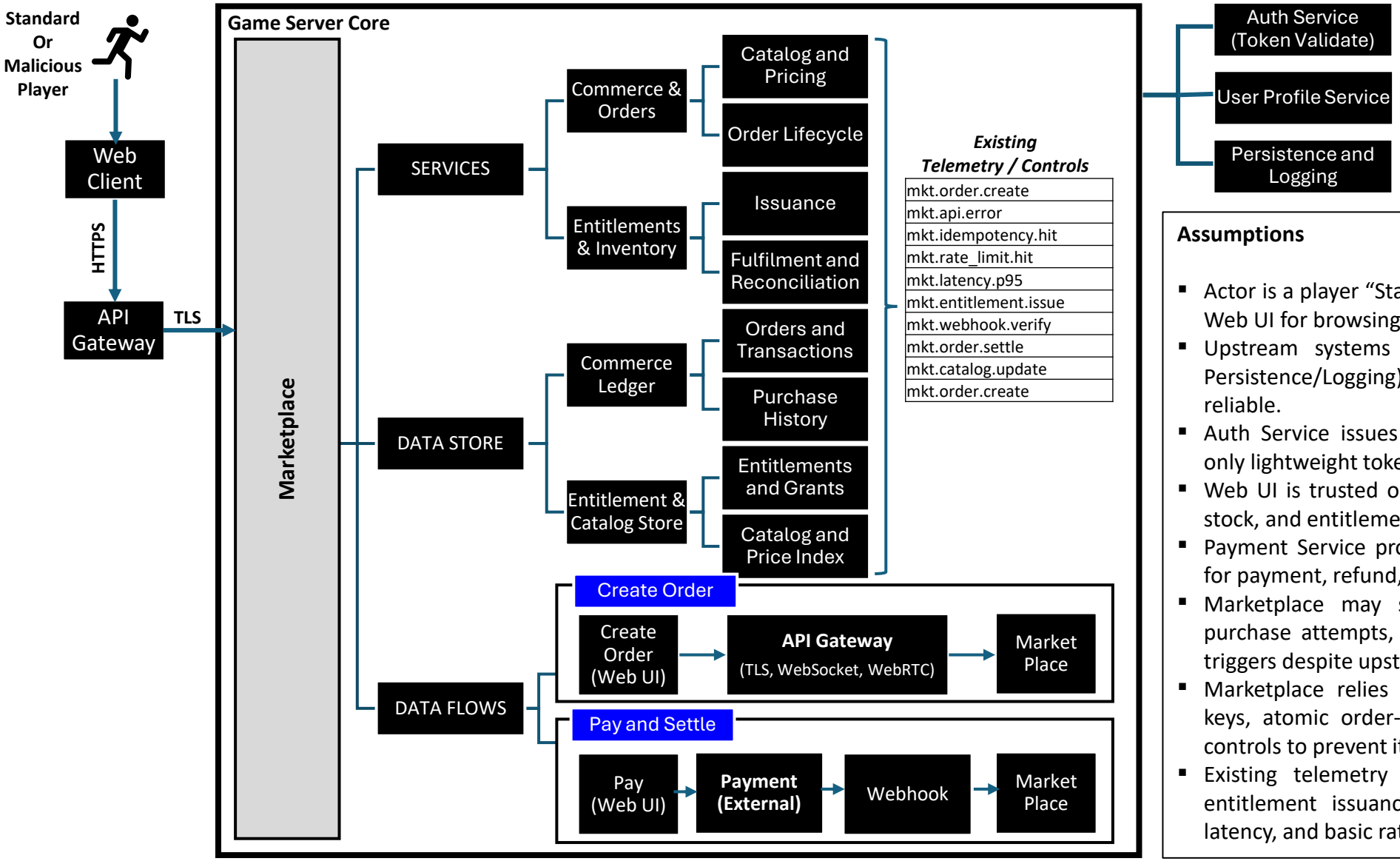
- game.exploit.flag (rule-violation classifier)
- game.action.pattern.anomaly (bot/timing detection)
- game.desync.detected (state drift detector)
- game.dos.signature (burst-window detector)
- game.packet.reject.reason
- game.overload.threshold.exceeded
- game.impersonation.check
- game.cohort.activity (correlated offender grouping)
- game.duplication.detected (atomicity/rollback mismatch)

Game Server – Catalog of Telemetry and Control Signals

Telemetry / Control	Description
game.action.recv	Server received a player action (input event).
game.action.reject	Server rejected a player action due to invalid state, auth failure, or rule violation.
game.action.rate_limit.hit	Action rejected/throttled because the player exceeded allowed action frequency.
game.state.sync.delta	State-diff update sent to clients during sync.
game.ws.error	Generic WebSocket transport or protocol error.
game.service.health	Periodic service heartbeat reporting system resource usage. (CPU/mem/active_sessions)
game.ws.error (malformed)	WebSocket error due to corrupted, malformed, or unparsable frame.
game.rate_limit.hit	General server-level rate limit event (not action-specific).
game.tick.latency	Raw tick latency for each simulation frame.
game.tick.latency.p95	95th percentile of server tick loop latency.
game.state.persist	State or snapshot successfully persisted (DB/write path).
game.exploit.flag	Rules engine identified suspected exploit behavior.
game.action.pattern.anomaly	Action-pattern anomaly detection (bot, timing irregularity).
game.desync.detected	Server-client state divergence detected.
game.dos.signature	Detected DoS-like burst/surge pattern.
game.packet.reject.reason	Dropped or rejected packet with specific schema reason.
game.overload.threshold.exceeded	System exceeded defined capacity threshold.
game.impersonation.check	Identity/auth mismatch or impersonation signal.
game.cohort.activity	Correlated cluster activity (potential collusion/cheating group).
game.duplication.detected	Duplicate actions or items detected (rollback/atomicity violation).

Team 29
Threat Modeling in Action
(Service # 3 - Marketplace)

Marketplace: Existing-State Architecture, Dependencies & Assumptions



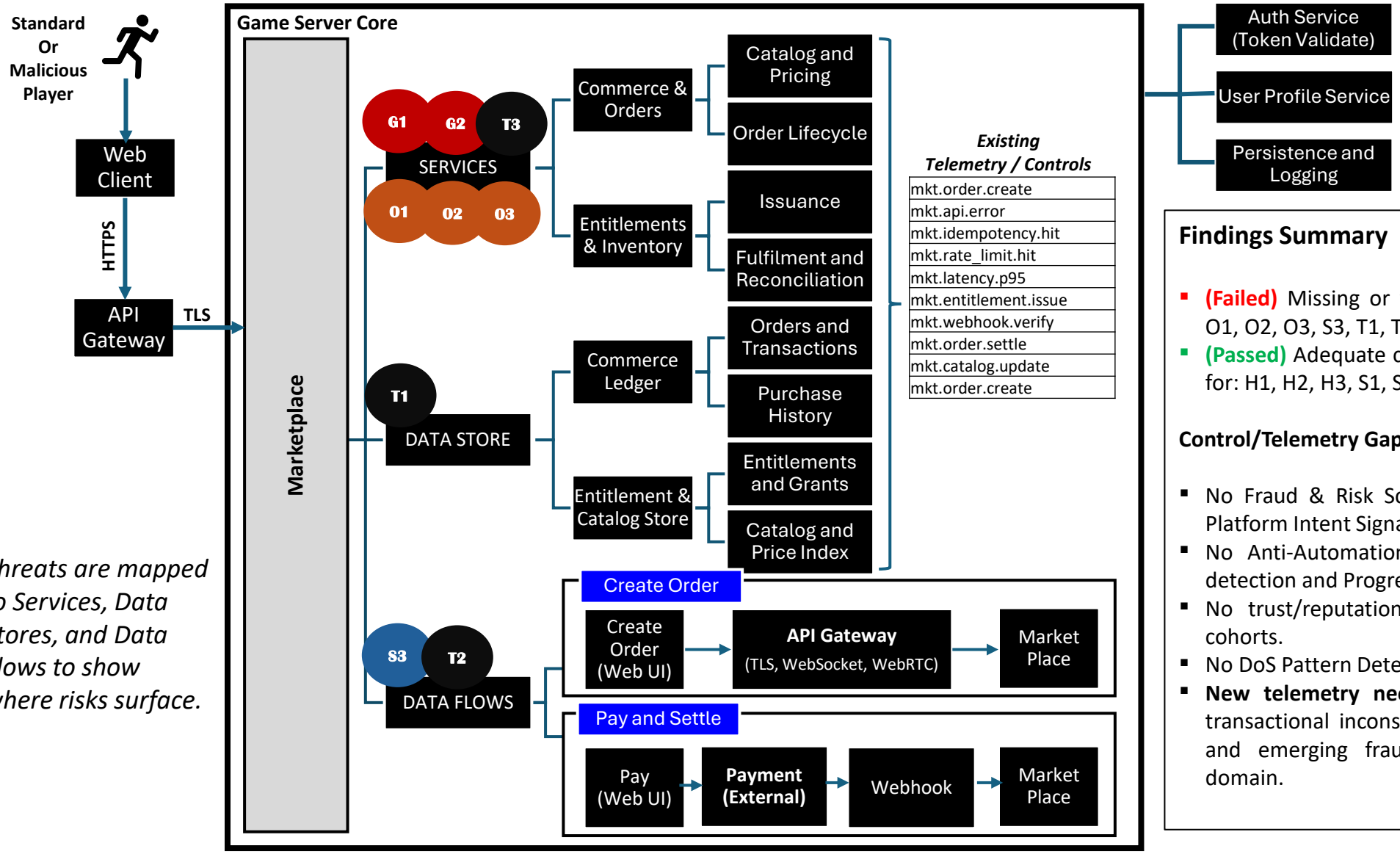
Assumptions

- Actor is a player "Standard or Malicious" using the normal Web UI for browsing, purchasing, and redeeming items.
- Upstream systems (Auth, User Profile, API Gateway, Persistence/Logging) are assumed to be available and reliable.
- Auth Service issues valid tokens; Marketplace performs only lightweight token checks.
- Web UI is trusted only for display and input—all pricing, stock, and entitlement logic is server-side.
- Payment Service provides signed, idempotent webhooks for payment, refund, and chargeback events.
- Marketplace may still receive spam orders, scripted purchase attempts, replayed requests, or race-condition triggers despite upstream filters.
- Marketplace relies on internal validation, idempotency keys, atomic order-to-entitlement flows, and fraud/risk controls to prevent item duping and market abuse.
- Existing telemetry covers order creation, settlement, entitlement issuance, refunds/chargebacks, API errors, latency, and basic rate-limits.

Marketplace - G.H.O.S.T. Threat Coverage and Control Gaps Analysis

Threat ID	Threat Name	Test Case	Existing Telemetry (Current Controls)	Finding	Result	Remediation Actions (Add Missing Telemetry & Controls)
G1	EXPLOTS	Force a checkout with stale price/region or bypass stock cap via replay; verify server re-prices and rejects invalid order.	mkt.order.create, mkt.api.error, mkt.idempotency.hit	Existing Marketplace policies do cover 100% rule violations.	FAIL	mkt.reprice.event (server-side reprice), mkt.policy.violation (cap/region/stock)
G2	CHEATS	Script 50 rapid small orders within 60s from one account/device; confirm caps/cooldowns throttle.	mkt.rate_limit.hit, mkt.order.create	Existing Marketplace policies do cover unexpected patterns like purchase velocity at a device/account level.	FAIL	mkt.purchase.velocity (per device/account), mkt.suspicious.pattern
G3	DESYNC	Induce client delay and submit checkout with outdated catalog snapshot; verify server authoritative pricing wins.	mkt.order.create, mkt.api.error (price_mismatch)	Not Possible in "Marketplace Boundary" Governance is External – Game Server Telemetry	PASS	Recommended: mkt.catalog.version.mismatch
H1	HARASSMENT	Send targeted abusive messages to a test user across multiple channels over 2 minutes.	(Not Applicable)	Not Possible in "Marketplace Boundary" Governance is External – Chat Telemetry	PASS	
H2	GROOMING	Adult test account messages a minor-flagged test account with boundary-pushing prompts over 48h.	(Not Applicable)	Not Possible in "Marketplace Boundary" Governance is External – Chat Telemetry	PASS	
H3	TOXICITY	Post sequences of offensive phrases in a public channel at normal cadence.	(Not Applicable)	Not Possible in "Marketplace Boundary" Governance is External – Chat Telemetry	PASS	
O1	DDoS	Generate high RPS to public marketplace endpoints (catalog/browse); validate WAF/rate-limits keep SLOs.	mkt.api.error (429/503), gateway/WAF logs, mkt.latency.p95	Existing Throttling and Health Checks are not adequate detect all DoS patterns.	FAIL	mkt.dos.signature (burst window)
O2	PACKET TAMPERING	Send malformed/oversized JSON on order create/settle; verify schema reject and no side effects.	mkt.api.error (400), mkt.webhook.verify	Existing Health Checks are not adequate prevent Payload Tampering attacks..	FAIL	mkt.payload.reject.reason (schema/size/signature)
O3	API OVERLOAD	Spam order create/cancel cycles to starve queue; confirm per-actor quotas and backpressure.	mkt.rate_limit.hit, mkt.latency.p95	Existing Rate Limit Configuration do not consider per use quota to manipulate queue depths.	FAIL	mkt.queue.depth, mkt.overload.threshold.exceeded
S1	CLAN INFILTRATION	Governance/social manipulation; Join a test clan and attempt manipulation,	(Not Applicable)	Not Possible in "Marketplace Boundary" Governance is External – Chat Telemetry	PASS	
S2	NAME IMPERSONATION	Create a homoglyph display name colliding with a high-rep user; Use in Game	(Not Applicable)	Not Possible in "Marketplace Boundary" Governance is External – Auth Service Telemetry	PASS	
S3	GROUP BRIGADING	30 accounts coordinate micro-orders to create load; confirm cohort throttling/quotas.	mkt.rate_limit.hit	Existing Rate Limit Configuration do not consider the time and multi-user dimension	FAIL	mkt.cohort.activity (correlated actors), mkt.cohort.limit.applied
T1	ITEM DUPING	Replay payment webhook or repeat grant call with same order_id; ensure idempotent single entitlement.	mkt.entitlement.issue (result), mkt.idempotency.hit	Existing Entitlement Policy Configuration do not cover duplicate order payloads.	FAIL	mkt.duplication.detected (grant/ownership conflict)
T2	MARKET FRAUD	Off-platform escrow scam: send paid webhook spoof; verify HMAC + idempotency + risk scoring blocks.	mkt.webhook.verify (ok/fail), mkt.order.settle	Existing Settlement Checks do not correlate fraud referrals from other components e.g., Chat.	FAIL	mkt.fraud.signal, mkt.fraud.referral_from_chat
T3	PRICE FIXING	3–4 sellers maintain floor price; detect cross-account correlation and enforce exposure caps.	mkt.order.create, mkt.catalog.update	Existing cross account correlation Configuration do not consider the time and multi-user dimension	FAIL	mkt.price.correlation, mkt.cartel.detected, mkt.exposure.limit.hit

Marketplace - G.H.O.S.T Threat Landscape and Findings



Threats are mapped to Services, Data Stores, and Data Flows to show where risks surface.

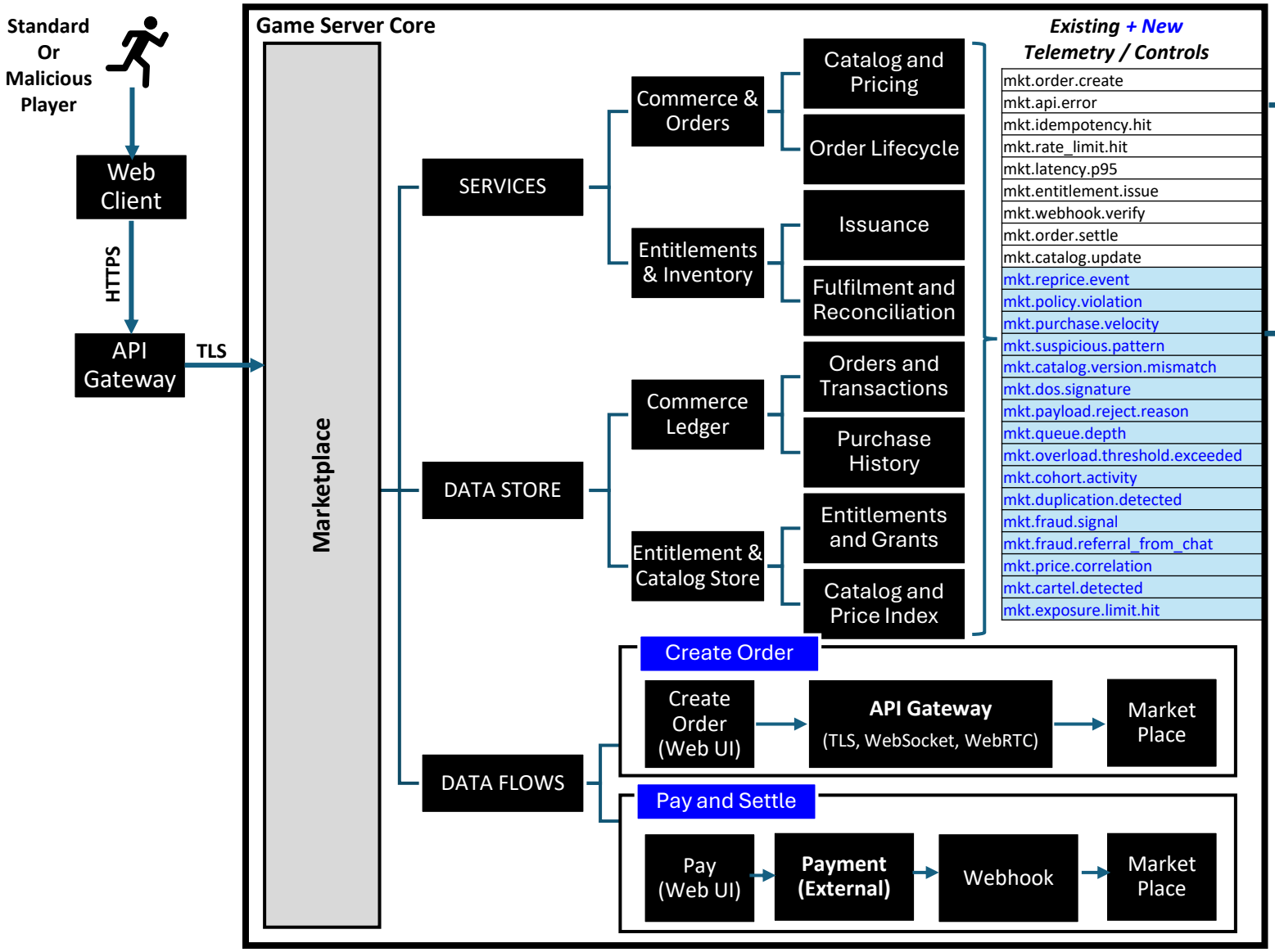
Findings Summary

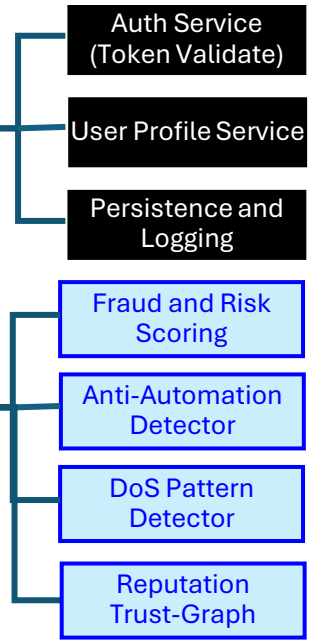
- **(Failed)** Missing or weak controls observed for: G1, G2, O1, O2, O3, S3, T1, T2, T3.
- **(Passed)** Adequate controls (or handled in other services) for: H1, H2, H3, S1, S2, G3.

Control/Telemetry Gaps Identified

- No Fraud & Risk Scoring for Rule-Violation and Out of Platform Intent Signals (Chat)
- No Anti-Automation Solution for Scripted-Buy pattern detection and Progressive Frictions.
- No trust/reputation model to throttle risky users or cohorts.
- No DoS Pattern Detectors.
- **New telemetry needed** to detect anomalous activity, transactional inconsistencies, coordinated user behavior, and emerging fraud threats within the marketplace domain.

Marketplace: Target-State Architecture, Controls and Remediation Strategy





New AI-Driven Safety Controls

- **Fraud and Risk Scoring** – identifies rule-violation, correlates ou-of-platform intents.
- **Anti-Automation Detector** – for Scripted-Buy pattern detection and progressive frictions.
- **DoS Pattern Detector** – detects burst windows and DoS signatures,
- **Reputation Trust-Graph** – models user trust levels and behavior history to guide throttles and controls.

Additional Telemetry to be Implemented

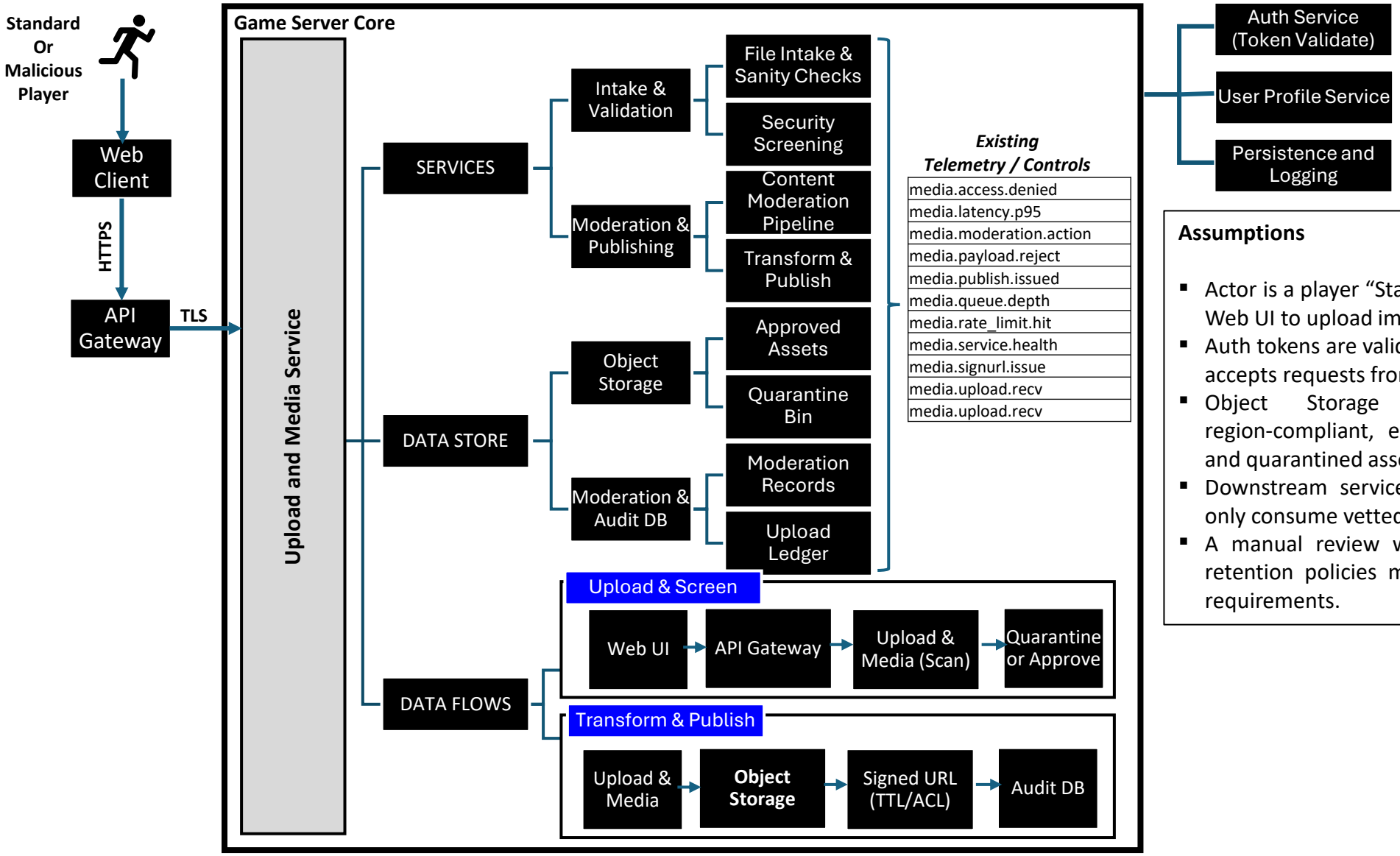
- mkt.reprice.event (server-side reprice)
- mkt.policy.violation (cap/region/stock)
- mkt.purchase.velocity (per device/account)
- mkt.suspicious.pattern, mkt.catalog.version.mismatch
- mkt.dos.signature (burst window)
- mkt.payload.reject.reason (schema/size/signature)
- mkt.queue.depth, mkt.overload.threshold.exceeded
- mkt.cohort.activity (correlated actors)
- mkt.cohort.limit.applied, mkt.exposure.limit.hit
- mkt.duplication.detected (grant/ownership conflict)
- mkt.fraud.signal, mkt.fraud.referral_from_chat
- mkt.price.correlation, mkt.cartel.detected

Marketplace – Catalog of Telemetry and Control Signals

Telemetry / Control	Description
mkt.order.create	Logs every order creation attempt to track success, failure, abuse, or anomalies.
mkt.api.error	Captures API-level errors (4xx/5xx) for diagnosing faults, misconfigurations, or suspicious error patterns.
mkt.idempotency.hit	Indicates repeated identical API calls, useful for detecting retries vs. replay or bot behavior.
mkt.rate_limit.hit	Shows when clients exceed allowed API call thresholds, useful for abuse or DOS detection.
mkt.latency.p95	Measures 95th-percentile latency to identify performance degradation or overload.
mkt.entitlement.issue	Flags entitlement or permission mismatches (e.g., unauthorized ownership or access).
mkt.webhook.verify	Tracks correctness and authenticity of incoming/outgoing webhook notifications.
mkt.order.settle	Logs settlement or finalization of orders to detect inconsistencies or fraud.
mkt.catalog.update	Monitors catalog-level changes that may affect pricing, availability, or integrity.
mkt.reprice.event	Server-side reprice events triggered by policy, fairness rules, or fraud interventions.
mkt.policy.violation	Indicates violations of caps, region-based rules, stock controls, or compliance policies.
mkt.purchase.velocity	Measures purchase frequency per device/account to detect bursts or scripted buying.
mkt.suspicious.pattern	General-purpose signal for unusual workflows, sequences, or behavioral anomalies.
mkt.catalog.version.mismatch	Detects inconsistent catalog versions across systems—potential for integrity or sync issues.
mkt.dos.signature	Identifies denial-of-service patterns (burst traffic, signature anomalies).
mkt.payload.reject.reason	Logs rejection reasons for malformed, oversized, or invalid request payloads.
mkt.queue.depth	Measures message queue backlog to detect congestion or performance bottlenecks.
mkt.overload.threshold.exceeded	Indicates system stress conditions when resource thresholds are breached.
mkt.cohort.activity	Tracks coordinated activity across accounts/devices that may imply collusion.
mkt.duplication.detected	Detects duplicate grants, purchases, or conflicting ownership states.
mkt.fraud.signal	High-level fraud indicator derived from internal or ML-driven scoring.
mkt.fraud.referral_from_chat	Fraud signal originating from chat service referrals or social engineering patterns.
mkt.price.correlation	Detects abnormal pricing manipulations or coordinated pricing behavior.
mkt.cartel.detected	Flags groups of actors behaving in sync (market manipulation, hoarding, collusion).
mkt.exposure.limit.hit	Indicates when exposure/risk caps are exceeded for an item, user, or cohort.
mkt.order.create	Logs every order creation attempt to track success, failure, abuse, or anomalies.
mkt.api.error	Captures API-level errors (4xx/5xx) for diagnosing faults, misconfigurations, or suspicious error patterns.

Team 29
Threat Modeling in Action
(Service # 4 – Upload and Media)

Upload & Media: Existing-State Architecture, Dependencies & Assumptions



Existing Telemetry / Controls

media.access.denied
media.latency.p95
media.moderation.action
media.payload.reject
media.publish.issued
media.queue.depth
media.rate_limit.hit
media.service.health
media.signurl.issue
media.upload.recv
media.upload.recv

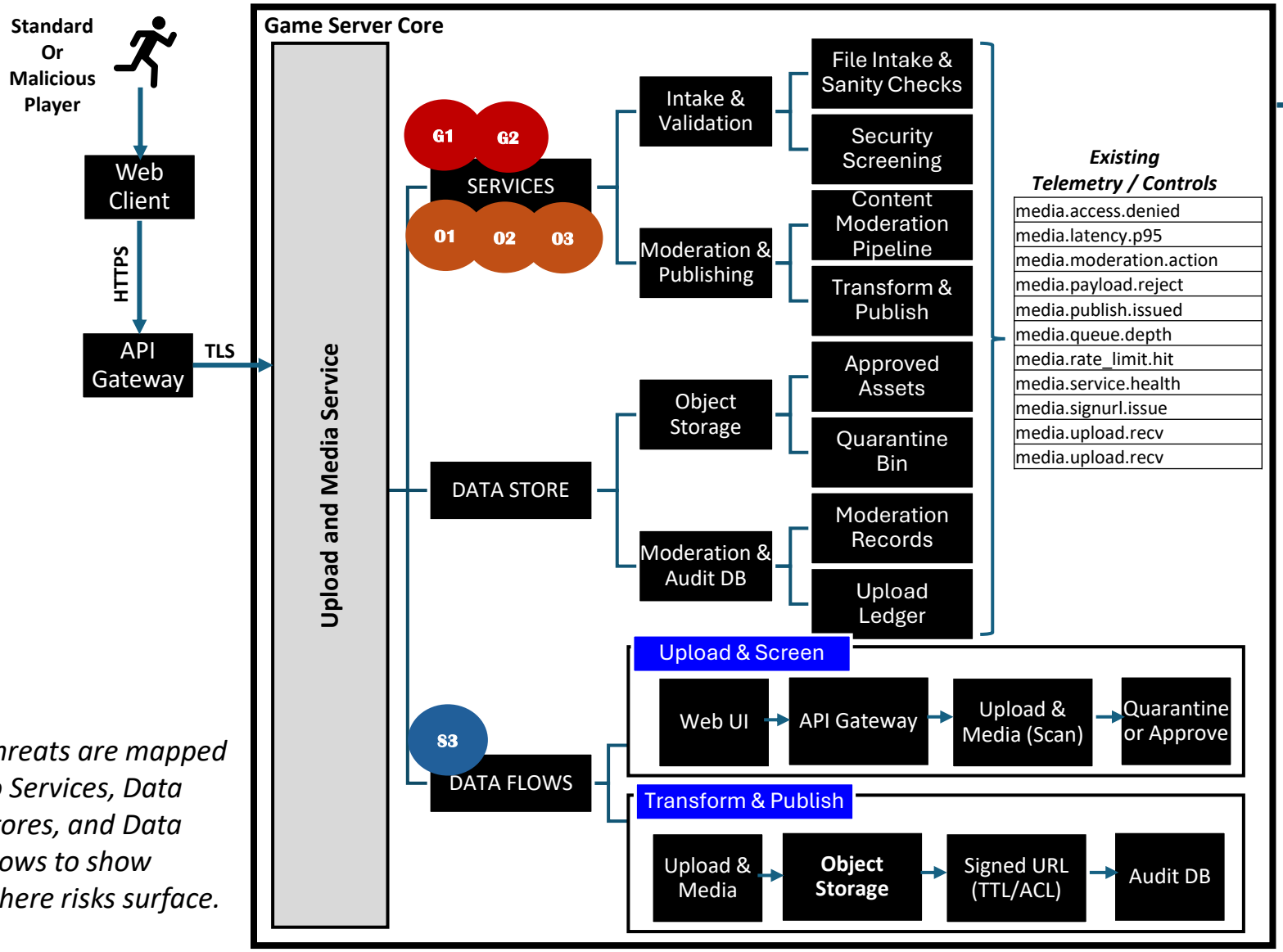
Assumptions

- Actor is a player "Standard or Malicious" using the normal Web UI to upload images or media.
- Auth tokens are validated upstream; Upload & Media only accepts requests from verified identities.
- Object Storage is durable, versioned, and region-compliant, ensuring safe retention of approved and quarantined assets.
- Downstream services never receive raw binaries—they only consume vetted, sanitized media via signed URLs.
- A manual review workflow exists for escalations, and retention policies meet regional safety and compliance requirements.

Upload & Media - G.H.O.S.T. Threat Coverage and Control Gaps Analysis

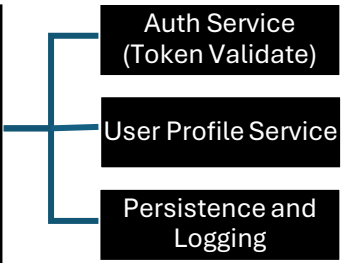
Threat ID	Threat Name	Test Case	Existing Telemetry (Current Controls)	Finding	Result	Remediation Actions (Add Missing Telemetry & Controls)
G1	EXPLOTS	Upload file with **disallowed type/oversized** content but spoofed extension; verify **MIME sniffing + size cap** reject and no publish.	media.upload.recv (size/type), media.payload.reject (basic)	Existing Media Upload policies do cover 100% rule violations.	FAIL	media.policy.violation, media.reject.reason (mime/size)
G2	CHEATS	Script **rapid, repeated uploads** to exhaust pipeline; confirm rate-limits/backpressure and no publish.	media.rate_limit.hit, media.queue.depth,media.latency.p95	Existing Media Upload policies do cover unexpected patterns like correlated events.	FAIL	media.overload.threshold.exceeded, media.cohort.activity (correlated actors)
G3	DESYNC	Not applicable—no client vs server state race relevant to media publish (server authoritative).	—	Not Possible in "Upload and Media Boundary" Governance is External – Game Server Telemetry	PASS	
H1	HARASSMENT	External to media; handled in Chat moderation.	—	Not Possible in "Upload and Media Boundary" Governance is External – Chat Telemetry	PASS	
H2	GROOMING	External (DM/chat). Images may be evidence, but grooming detection is chat-side.	—	Not Possible in "Upload and Media Boundary" Governance is External – Chat Telemetry	PASS	
H3	TOXICITY	Textual chat issue; not media pipeline's responsibility.	—	Not Possible in "Upload and Media Boundary" Governance is External – Chat Telemetry	PASS	
O1	DDoS	**High-RPS upload attempts** / large-file floods; verify Gateway and service **rate-limits**, chunk throttling, and stability.	media.rate_limit.hit, media.service.health,	Existing Throttling and Health Checks are not adequate detect all DoS patterns.	FAIL	media.dos.signature (burst window), media.bandwidth.gauge
O2	PACKET TAMPERING	Send **corrupted/invalid multipart** or malformed chunk; confirm **parser reject** and no object write.	media.upload.recv (attempt), media.payload.reject	Existing Health Checks are not adequate prevent Payload Tampering attacks..	FAIL	media.payload.reject.reason (schema/chunk/CRC), media.parser.error
O3	API OVERLOAD	Spam **thumbnail/transform** API or signed-URL requests; ensure quotas/backoff and SLOs hold.	media.latency.p95, media.rate_limit.hit, media.signurl.issue	Existing Rate Limit Configuration do not consider per user quota to manipulate queue depths.	FAIL	media.overload.threshold.exceeded, media.transform.queue.depth
S1	CLAN INFILTRATION	Social governance; out of media scope.	—	Not Possible in "Upload and Media Boundary" Governance is External – Chat Telemetry	PASS	
S2	NAME IMPERSONATION	Identity policy (Auth/Profile). Media may host avatars, but impersonation check is upstream.		Not Possible in "Upload and Media Boundary" Governance is External – Auth Service Telemetry	PASS	
S3	GROUP BRIGADING	**Coordinated upload surge** (e.g., mass NSFW attempts); detect cohort → throttle/quarantine.	media.rate_limit.hit, media.moderation.action	Existing Rate Limit Configuration do not consider the time and multi-user dimension	FAIL	media.cohort.activity, media.cohort.limit.applied
T1	ITEM DUPING	Duping is marketplace/economy; media only publishes assets/links.	—	Not Possible in "Upload and Media Boundary" Governance is External – Marketplace Telemetry	PASS	
T2	MARKET FRAUD	Fraud is marketplace/links; media can **strip risky embeds/metadata** and enforce **signed URLs**.	media.publish.issued (signed URL), media.access.denied	Existing Telemetry is adequate to identify and block files with risky metadata and without signed URLs	PASS	Recommended: media.url.verdict
T3	PRICE FIXING	Economic behavior; not a media function.	—	Not Possible in "Upload and Media Boundary" Governance is External – Marketplace Telemetry	PASS	

Upload & Media - G.H.O.S.T Threat Landscape and Findings



Existing Telemetry / Controls

media.access.denied
media.latency.p95
media.moderation.action
media.payload.reject
media.publish.issued
media.queue.depth
media.rate_limit.hit
media.service.health
media.signurl.issue
media.upload.recv
media.upload.recv



Findings Summary

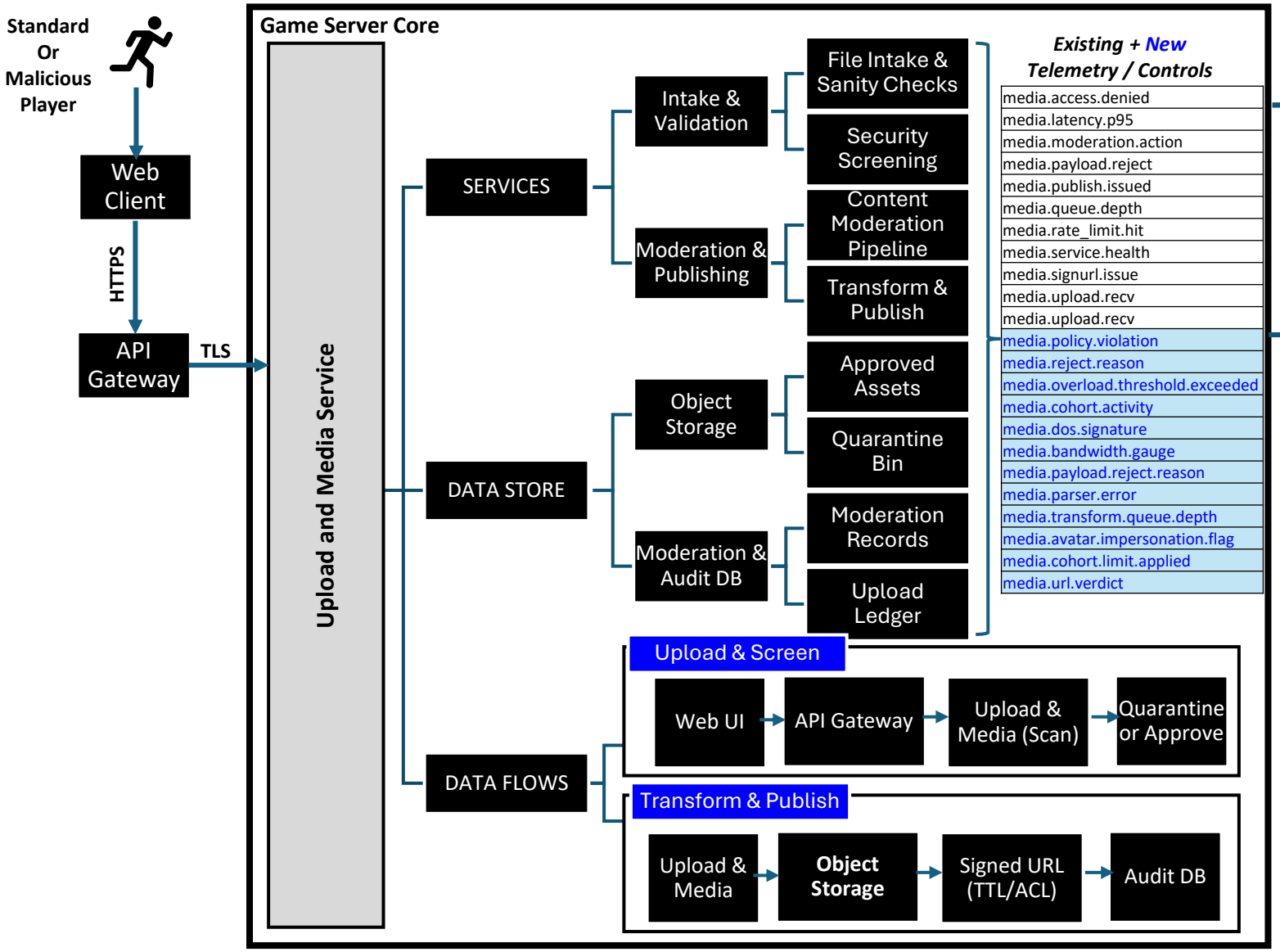
- **(Failed)** Missing or weak controls observed for: G1, G2, O1, O2, O3, S3, T1, T2, T3.
- **(Passed)** Adequate controls (or covered by other services) for: H1, H2, H3, S1, S2, G3.

Control/Telemetry Gaps Identified

- No Content Integrity Checker that identifies unsafe or policy-violating media, blocks automated or high-velocity upload abuse.
- No trust/reputation model to throttle risky users or cohorts.
- No DoS Pattern Detectors.
- **New telemetry needed** to detect unsafe or anomalous uploads, including abnormal file patterns, upload velocity anomalies, coordinated behavior, DoS attempts, corrupted files, repeated failures, and integrity violations.

Threats are mapped to Services, Data Stores, and Data Flows to show where risks surface.

Upload&Media: Target-State Architecture, Controls & Remediation Strategy



New AI-Driven Safety Controls

- **Content Integrity AI** –is a unified detection pipeline that identifies unsafe or policy-violating media
- **DoS Pattern Detector** – detects burst windows and DoS signatures,
- **Reputation Trust-Graph** – models user trust levels and behavior history to guide throttles and controls.

Additional Telemetry to be Implemented

- media.policy.violation — rule breach
- media.reject.reason — rejection cause
- media.overload.threshold.exceeded — capacity exceeded
- media.cohort.activity — group behavior
- media.dos.signature — DoS pattern
- media.bandwidth.gauge — usage meter
- media.payload.reject.reason — payload invalid
- media.parser.error — parse failure
- media.transform.queue.depth — queue backlog
- media.avatar.impersonation.flag — identity spoofing
- media.cohort.limit.applied — group throttled
- media.url.verdict — URL risk

Upload & Media – Catalog of Telemetry and Control Signals

Telemetry / Control	Description
media.access.denied	Attempt to fetch an asset was blocked (e.g., expired/invalid signed URL, ACL/policy violation).
media.latency.p95	95th-percentile processing latency for the upload/scan/moderation/publish pipeline.
media.moderation.action	Final moderation decision recorded (approve/reject/quarantine) with actor (auto/manual).
media.payload.reject	Upload payload rejected at intake (type/size whitelist, malware hit, archive limits).
media.publish.issued	Asset published to storage/CDN and a signed URL was created (with TTL/ACL).
media.queue.depth	Current queue depth for pipeline stages (scan, moderation, transform).
media.rate_limit.hit	Per-user/IP upload rate limit or burst threshold was triggered.
media.service.health	Service health gauge (CPU, memory, open fds, backlog, error rate).
media.signurl.issue	Failure while issuing a signed URL (policy conflict, key problem, backend error).
media.upload.recv	Upload received; records uploader, size, MIME, checksum, and intake timestamp.
media.policy.violation	Automated/Manual detection of policy-violating content (e.g., NSFW, prohibited imagery).
media.reject.reason	Canonical reason code for any rejection (policy, scan, size, MIME, signature).
media.overload.threshold.exceeded	Backpressure/overload condition triggered; throttling or admission control engaged.
media.cohort.activity	Correlated upload activity detected across accounts/devices (potential brigading/raids).
media.dos.signature	DoS/burst fingerprint identified (e.g., synchronized large uploads from many sources).
media.bandwidth.gauge	Ingress/egress bandwidth utilization by bucket/region or endpoint.
media.payload.reject.reason	Structured schema for intake-reject details (oversized, malformed, archive depth, malware).
media.parser.error	Parser/decoder failed during inspection or transform (bad header/format).
media.transform.queue.depth	Queue depth specifically for image/video transforms (resize, transcode, metadata strip).
media.avatar.impersonation.flag	Suspected avatar/name/logo impersonation flagged during moderation.
media.cohort.limit.applied	Enforcement applied to a cohort (e.g., slow-mode, block, quota reduction).
media.url.verdict	Verdict on embedded/referenced URLs (allow/warn/strip/block) from reputation/sandbox checks.

Threat Model Analysis Report and Graphs

(What we delivered, also as an Executive-View !)

Threat Dashboard and Threat Radar (Executive View)

This dashboard and radar is an actual representation of the threat modeling completed for the chat, game server, marketplace and media & upload services using the G.H.O.S.T framework. It highlights how high-impact, representative threats map to each system component.

(please note - same content was showcased as an early view in slide 18, as our target deliverable)

#	System Component	G1	G2	G3	H1	H2	H3	O1	O2	O3	S1	S2	S3	T1	T2	T3	Risk Level	More Info.
1	Chat Service (real-time)	🟢	🟢	🟢	🔴	🔴	🔴	🟢	🟢	🔴	🟢	🔴	🔴	🟢	🔴	🟢	🟥	link
2	Game Server Cluster (real-time)	🔴	🔴	🔴	🟢	🟢	🟢	🔴	🔴	🔴	🟢	🔴	🔴	🔴	🟢	🟢	🟥	link
3	Market Place	🔴	🔴	🟢	🟢	🟢	🟢	🔴	🔴	🔴	🟢	🟢	🔴	🔴	🔴	🔴	🟥	Link
4	Media and Upload Service	🔴	🔴	🟢	🟢	🟢	🟢	🔴	🔴	🔴	🟢	🟢	🔴	🟢	🟢	🟢	🟨	Link

Action Plan and Prioritization

(What the game developers need to do and by when !)

Observability and Telemetry Development Action Plan with Prioritization

This action plan outlines the required additional telemetry to be developed for each service in scope of our threat modeling and organizes it into Priority 1, 2, and 3 based on the below criteria.

P1 = foundational safety, fraud, or system-integrity signals (Target to complete in less than ~4 weeks)
P2 = performance, cohort-based or anomaly-based controls (Target to complete in less than ~12 weeks)
P3 = enrichment or advanced correlation signals (Target to complete in less than ~24 weeks)

Chat Service

Telemetry	Priority
chat.msg.score	P1
chat.msg.policy.coppa	P1
chat.url.verdict	P1
chat.trade.intent	P1
chat.impersonation.check	P2
chat.rate_limit.cohort	P2
chat.inline.latency	P3

Game Server

Telemetry	Priority
game.exploit.flag	P1
game.action.pattern.anomaly	P1
game.desync.detected	P1
game.duplication.detected	P1
game.dos.signature	P2
game.packet.reject.reason	P2
game.overload.threshold.exceeded	P2
game.cohort.activity	P2
game.impersonation.check	P3
game.exploit.flag	P1
game.action.pattern.anomaly	P1
game.desync.detected	P1
game.duplication.detected	P1
game.dos.signature	P2
game.packet.reject.reason	P2
game.overload.threshold.exceeded	P2
game.cohort.activity	P2
game.impersonation.check	P3

Marketplace

Telemetry	Priority
mkt.reprice.event	P1
mkt.policy.violation	P1
mkt.purchase.velocity	P1
mkt.payload.reject.reason	P1
mkt.duplication.detected	P1
mkt.fraud.signal	P1
mkt.fraud.referral_from_chat	P1
mkt.price.correlation	P1
mkt.cartel.detected	P1
mkt.dos.signature	P2
mkt.suspicious.pattern	P2
mkt.queue.depth	P2
mkt.overload.threshold.exceeded	P2
mkt.cohort.activity	P2
mkt.cohort.limit.applied	P3
mkt.exposure.limit.hit	P3
mkt.catalog.version.mismatch	P3

Media and Upload

Telemetry	Priority
media.policy.violation	P1
media.reject.reason	P1
media.payload.reject.reason	P1
media.url.verdict	P1
media.avatar.impersonation.flag	P1
media.dos.signature	P2
media.overload.threshold.exceeded	P2
media.cohort.activity	P2
media.bandwidth.gauge	P2
media.parser.error	P3
media.transform.queue.depth	P3
media.cohort.limit.applied	P3

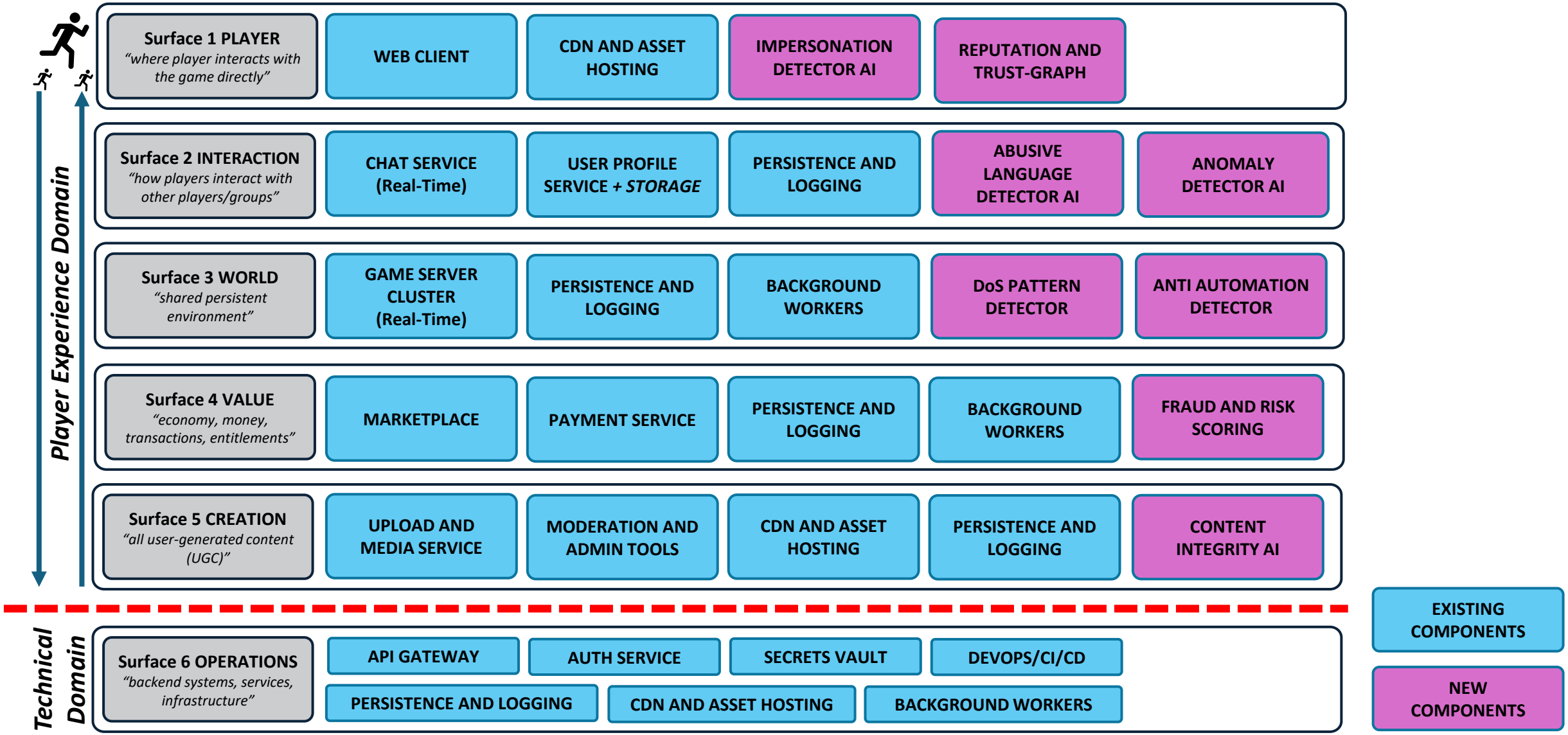
New Services High-Level Development Action Plan and Prioritization

This action plan defines the AI and AI-enabled solutions to be built across services. We prioritize implementations that protect player safety, prevent fraud/abuse, and safeguard system integrity and availability before advanced correlation and enrichment. All identified actions are expected to be completed in ~ 8 weeks for Priority 1 Actions and ~ 16 weeks for Priority 2 Actions.

New Solution	Solution Type	Description	Priority
DoS Pattern Detector	Programmatic	Identifies burst-window attacks, volumetric anomalies, and API-shape deviations impacting availability.	**P1 (~ 8 weeks)**
Impersonation Detector AI	AI Enabled	Detects identity spoofing across chat, game server, marketplace surfaces, and uploaded avatars/media (homoglyph + visual similarity).	**P1 (~ 8 weeks)**
Abusive Language Detector AI	AI Enabled	Identifies toxicity, harassment, grooming, and harmful text patterns in real time.	**P1 (~ 8 weeks)**
Anti-Automation Detector	AI Enabled	Detects script-driven actions, synthetic clicks, or nonhuman interaction patterns.	**P1 (~ 8 weeks)**
Fraud & Risk Scoring Engine	AI Enabled	Evaluates transaction, settlement, and cross-surface behavioral signals to block fraudulent activity.	**P1 (~ 8 weeks)**
Content Integrity AI	AI Enabled	Analyzes uploaded media (images, avatars, content) for policy violations, harmful or unsafe materials, and clone/collusion signals.	**P1 (~ 8 weeks)**
Reputation & Trust-Graph	AI Enabled	Builds cross-service trust and behavioral reputation signals to support moderation, rate limits, fraud detection, and cohort-risk scoring.	**P2 (~ 16 weeks)**
Anomaly Detector AI	AI Enabled	Learns expected behavioral baselines and flags deviations (botting, timing abuse, desync patterns, unusual activity).	**P2 (~ 16 weeks)**

Target Business Architecture

Target Business Architecture: Existing + New Components



Future Outlook

Operationalizing G.H.O.S.T

(What opportunities exist beyond the TMC 2026 Hackathon ?)

Operationalizing G.H.O.S.T - Example View Only

This dashboard is a mock-up based on the G.H.O.S.T framework, illustrating how representative, high-impact threats map to each system component. Only a subset of systems were analyzed for the hackathon. The aspiration is to eventually automate and operationalize this type of threat analysis across the platform.

#	System Component	G1	G2	G3	H1	H2	H3	O1	O2	O3	S1	S2	S3	T1	T2	T3	Risk Level	More Info.
1	Chat Service (real-time)	🟢	🟢	🟢	🔴	🔴	🔴	🟢	🟢	🔴	🟢	🔴	🔴	🟢	🔴	🟢	🔴	
2	Game Server Cluster (real-time)	🔴	🔴	🔴	🟢	🟢	🟢	🔴	🔴	🔴	🟢	🔴	🔴	🔴	🟢	🟢	🔴	
3	Marketplace	🔴	🔴	🟢	🟢	🟢	🟢	🔴	🔴	🔴	🟢	🟢	🔴	🔴	🔴	🔴	🔴	
4	Auth Service (Identity)	🟢	🟢	🟢	🔴	🔴	🔴	🟠	🔴	🔴	🟠	🟠	🟠	🟢	🔴	🟢	🟠	
5	Payment Service (External)	🔴	🔴	🔴	🟢	🟢	🟠	🔴	🔴	🔴	🟠	🔴	🟢	🔴	🟢	🟢	🟠	
6	Persistence & Logging	🔴	🔴	🟢	🟢	🟢	🟠	🟠	🟠	🟠	🟠	🔴	🟢	🔴	🟢	🟢	🟠	
7	API Gateway	🟢	🟢	🟢	🔴	🔴	🔴	🟠	🔴	🔴	🟢	🟠	🟠	🟢	🔴	🟢	🔴	
8	Moderation & Admin Tools	🔴	🔴	🔴	🟢	🟢	🟠	🔴	🔴	🔴	🟠	🔴	🟢	🔴	🟢	🟢	🔴	
9	Upload & Media Service	🔴	🔴	🟢	🟢	🟢	🟢	🔴	🔴	🔴	🟢	🟢	🔴	🟢	🟢	🟢	🟠	
10	Secrets Vault	🟢	🟢	🟢	🔴	🔴	🔴	🟠	🔴	🔴	🟢	🟠	🟠	🟢	🔴	🟢	🟠	
11	Web Client (browser SPA)	🔴	🔴	🔴	🟢	🟢	🟠	🔴	🔴	🔴	🟠	🔴	🟢	🔴	🟢	🟢	🟠	
12	User Profile Service + Storage	🔴	🔴	🟢	🟢	🟢	🟠	🟠	🟠	🟠	🟠	🔴	🟢	🔴	🟢	🟢	🟠	
13	DevOps / CI/CD	🟢	🟢	🟢	🟢	🟢	🟢	🟢	🟢	🟢	🟢	🟢	🟢	🟢	🟢	🟢	🟢	
14	Background Workers	🔴	🔴	🔴	🟢	🟢	🟠	🔴	🔴	🔴	🟠	🔴	🟢	🔴	🟢	🟢	🔴	
15	CDN & Asset Hosting	🔴	🔴	🟢	🟢	🟢	🟠	🟠	🟠	🟠	🟠	🔴	🟢	🔴	🟢	🟢	🔴	

This is an Example (Not Based on Real Data)

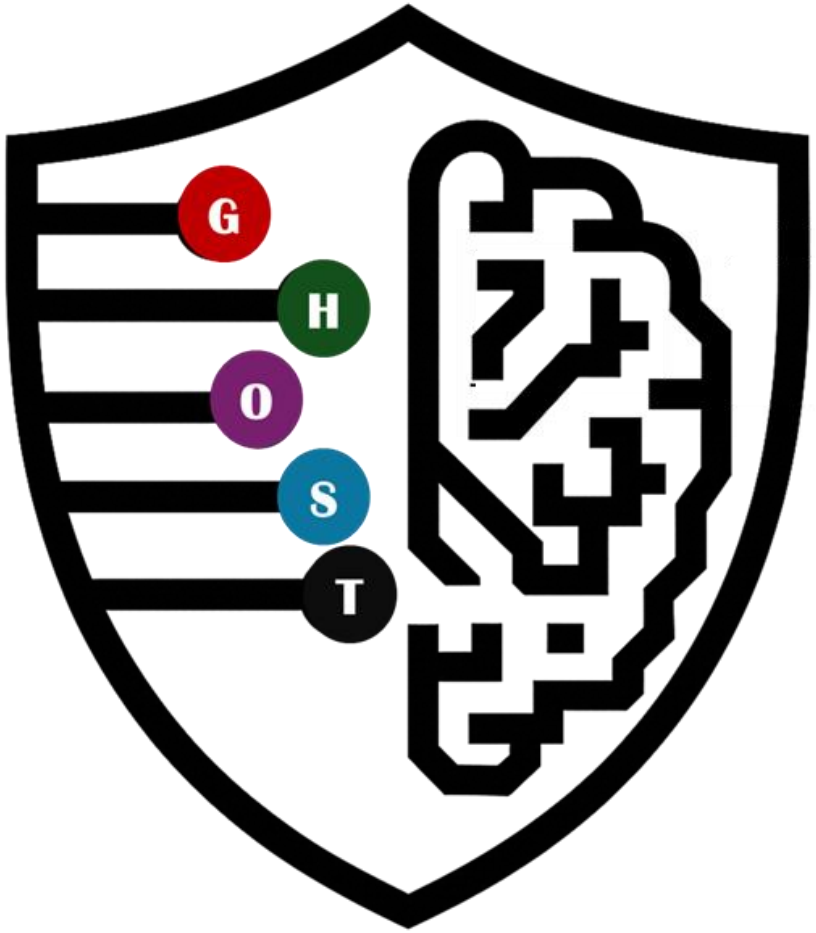
Appendix
High Resolution Diagrams and References

High Resolution Diagrams and References (Appendix)

Component Flow Sequence DFD	Threat Actors Context DFD	Chat Service Overview DFD	Game Server Overview DFD	Marketplace Overview DFD	Media and Upload Overview DFD
Component Sequence	Threat Actors	Chat Service	Game Server	Marketplace	Media and Upload

OWASP Top 10
https://owasp.org/www-project-top-ten/

CMS.gov CyberGeek
https://security.cms.gov/posts/evaluating-threat-modeling-methodologies

Online Tools
https://app.diagrams.net/
https://mermaid.live/
https://copilot.microsoft.com/

Thank You